



## Cyber Security (CYBER); CRA; Cybersecurity requirements for internet connected toys

Exercising one of the Principles of international standardization - Openness - and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

### Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

### Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

### How to comment

To comment or provide feedback on the present interim draft please visit: [STAN4CRA / EN 304 633 Internet connected toys · GitLab](#) and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: [cybersupport@etsi.org](mailto:cybersupport@etsi.org) using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

---

**Reference**DEN/CYBER-EUS-004

---

---

**Keywords**CRA, cybersecurity

---

0

**ETSI**

650 Route des Lucioles  
F-06921 Sophia Antipolis Cedex - FRANCE

---

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B  
Association à but non lucratif enregistrée à la  
Sous-Préfecture de Grasse (06) N° w061004871

---

**Important notice**

The present document can be downloaded from the  
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,  
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to  
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our  
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

---

**Notice of disclaimer & limitation of liability**

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

---

**Copyright Notification**

Reproduction is only permitted for the purpose of standardization work undertaken within ETSI.  
The copyright and the foregoing restrictions extend to reproduction in all media.

© ETSI 2026.  
All rights reserved.

# Contents

|    |                                                                                                         |    |
|----|---------------------------------------------------------------------------------------------------------|----|
| 1  | Intellectual Property Rights.....                                                                       | 7  |
| 2  | Foreword.....                                                                                           | 7  |
| 3  | Modal verbs terminology .....                                                                           | 8  |
| 4  | 1 Scope.....                                                                                            | 9  |
| 5  | 2 References.....                                                                                       | 9  |
| 6  | 2.1 Normative references.....                                                                           | 9  |
| 7  | 2.2 Informative references.....                                                                         | 9  |
| 8  | 3 Definition of terms, symbols and abbreviations.....                                                   | 10 |
| 9  | 3.1 Terms.....                                                                                          | 10 |
| 10 | 3.2 Symbols.....                                                                                        | 14 |
| 11 | 3.3 Abbreviations.....                                                                                  | 14 |
| 12 | 4 Product context.....                                                                                  | 14 |
| 13 | 4.1 Product functions.....                                                                              | 14 |
| 14 | 4.2 Product Architecture.....                                                                           | 16 |
| 15 | 4.3 Operational Environment.....                                                                        | 17 |
| 16 | 4.4 Interface.....                                                                                      | 17 |
| 17 | 4.5 Distribution of security functions.....                                                             | 17 |
| 18 | 4.6 Users.....                                                                                          | 18 |
| 19 | 4.7 Use cases.....                                                                                      | 18 |
| 20 | 4.7.1 General.....                                                                                      | 18 |
| 21 | 4.7.2 Use case profiles.....                                                                            | 18 |
| 22 | 4.8 Security Profiles.....                                                                              | 18 |
| 23 | 5 Requirements specifications.....                                                                      | 20 |
| 24 | 5.1 Product's technical requirements specifications.....                                                | 20 |
| 25 | 5.1.1 Known exploitable vulnerabilities.....                                                            | 20 |
| 26 | 5.1.1.1 [NKEV-MKAV] No known exploitable vulnerabilities.....                                           | 20 |
| 27 | 5.1.1.2 [NKEV-SUM-SUPPORT] Secure software update mechanism.....                                        | 20 |
| 28 | 5.1.1.3 [NKEV-SUM-PROVIDE] Secure software update mechanism for core components.....                    | 20 |
| 29 | 5.1.1.4 [NKEV-SUM-AUTO] Automated security updates.....                                                 | 20 |
| 30 | 5.1.1.5 [NKEV-SUM-NOTIF] Update notifications.....                                                      | 20 |
| 31 | 5.1.2 Default configuration.....                                                                        | 20 |
| 32 | 5.1.2.1 [SDC-AUM-FH] Default configuration of authentication for functions whose use can cause harm ... | 20 |
| 33 | 5.1.2.2 [SDC-SUM-AUTO] Default configuration of automated security updates.....                         | 21 |
| 34 | 5.1.2.3 [SDC-SUM-NOTIF] Default configuration of update notifications.....                              | 21 |
| 35 | 5.1.2.4 [SDC-FRM] Factory reset to restore the default state.....                                       | 21 |
| 36 | 5.1.2.5 [SDC-PARCONT] Default configuration for parental control.....                                   | 21 |
| 37 | 5.1.3 Authentication and access control mechanisms.....                                                 | 21 |
| 38 | 5.1.3.1 [ACM-FH] Access control for functions whose use can cause harm.....                             | 21 |
| 39 | 5.1.3.2 [PARCONT] Support of parental control.....                                                      | 22 |
| 40 | 5.1.3.3 [AUM-FH] Authentication for functions whose use can cause harm.....                             | 22 |
| 41 | 5.1.3.4 [AUTHZ-LP] Least privilege in authorization policies.....                                       | 23 |
| 42 | 5.1.3.5 [AUTHZ-R] Revocability of granted permissions.....                                              | 23 |
| 43 | 5.1.3.6 [AUTHZ-PC] Authorization policies for parental control.....                                     | 23 |
| 44 | 5.1.4 Integrity protection.....                                                                         | 23 |
| 45 | 5.1.4.1 [INT-SWPCK] Software package verification.....                                                  | 23 |
| 46 | 5.1.4.2 [INT-COM] Communication of integrity relevant data.....                                         | 24 |
| 47 | 5.1.5 Confidentiality protection.....                                                                   | 24 |
| 48 | 5.1.5.1 [CONF-SSM] Confidentiality protecting persistent storage for confidential data.....             | 24 |
| 49 | 5.1.5.2 [CONF-COM] Communication of confidential data.....                                              | 25 |
| 50 | 5.1.6 Data minimization.....                                                                            | 25 |
| 51 | 5.1.6.1 [DMIN-DJST] Documented justification of processed data.....                                     | 25 |
| 52 | 5.1.7 Availability protection.....                                                                      | 25 |
| 53 | 5.1.7.1 [AVAI-TIME-RECO-POW] Restoration after loss of power.....                                       | 25 |
| 54 | 5.1.7.2 [AVAI-TIME-NETW] Local operation.....                                                           | 26 |
| 55 |                                                                                                         |    |

|     |                               |                                                                                                |           |
|-----|-------------------------------|------------------------------------------------------------------------------------------------|-----------|
| 56  | 5.1.7.3                       | [AVAI-TIME-RECO-NETW] Restoration after loss of network connection .....                       | 26        |
| 57  | 5.1.7.4                       | [AVAI-TIME-OUTA-NOT] Notify non-availability .....                                             | 26        |
| 58  | 5.1.7.5                       | [AVAI-TIME-PREV-NOT] Notify upcoming limitation .....                                          | 26        |
| 59  | 5.1.7.6                       | [AVAI-TIME-NET-PRIO] Network prioritization .....                                              | 26        |
| 60  | 5.1.7.7                       | [AVAI-TIME-RES-PRIO] Resource prioritization .....                                             | 26        |
| 61  | 5.1.7.8                       | [AVAI-TIME-IMP-AMP] Amplification control .....                                                | 26        |
| 62  | 5.1.7.9                       | [AVAI-TIME-DOS-RATE] Incoming rate limiting .....                                              | 27        |
| 63  | 5.1.7.10                      | [AVAI-SUM-SCHEDULE] Scheduling of updates .....                                                | 27        |
| 64  | 5.1.8                         | Impact minimization .....                                                                      | 27        |
| 65  | 5.1.9                         | Limit attack surface .....                                                                     | 27        |
| 66  | 5.1.9.1                       | [LAS-INVAL] Validation of external data input .....                                            | 27        |
| 67  | 5.1.9.2                       | [LAS-INSAN] Sanitization of external data input .....                                          | 27        |
| 68  | 5.1.9.3                       | [LAS-PHY-INF] Only necessary physical interfaces .....                                         | 27        |
| 69  | 5.1.9.4                       | [LAS-LOGIC-INF] Only necessary logical interfaces active by default .....                      | 27        |
| 70  | 5.1.9.5                       | [LAS-APP] Only necessary apps by default .....                                                 | 27        |
| 71  | 5.1.9.6                       | [LAS-SBOOT] Secure boot .....                                                                  | 28        |
| 72  | 5.1.10                        | Logging and monitoring mechanisms .....                                                        | 28        |
| 73  | 5.1.10.1                      | [LOG-LOW] Events to log for low risk ICT .....                                                 | 28        |
| 74  | 5.1.10.2                      | [LOG-MEDIUM] Events to log for medium risk ICT .....                                           | 28        |
| 75  | 5.1.10.3                      | [LOG-HIGH] Events to log for high risk ICT .....                                               | 28        |
| 76  | 5.1.10.4                      | [LOG-TIME] Timestamps for logs .....                                                           | 29        |
| 77  | 5.1.10.5                      | [LOG-TIME-HIGH] Real-Timestamps for logs .....                                                 | 29        |
| 78  | 5.1.10.6                      | [LOG-STORAGE] Persistently store logfiles .....                                                | 29        |
| 79  | 5.1.10.7                      | [LOG-BACKUP] Backup of logfiles .....                                                          | 29        |
| 80  | 5.1.11                        | Deletion mechanisms .....                                                                      | 29        |
| 81  | 5.1.12                        | Other product's technical requirements specifications .....                                    | 29        |
| 82  | 5.1.12.1                      | [USERNOT-NOSECFCUC] User notifications on not available security functions .....               | 29        |
| 83  | 5.2                           | Requirements specifications for vulnerability handling activities related to the product ..... | 29        |
| 84  | 6                             | Assessing for compliance with requirements .....                                               | 29        |
| 85  | 6.1                           | Assessing for compliance with product's technical requirements specifications .....            | 29        |
| 86  | 6.1.1                         | General .....                                                                                  | 29        |
| 87  | 6.1.2                         | Known exploitable vulnerabilities .....                                                        | 30        |
| 88  | 6.1.2.1                       | Assessment criteria for [NKEV-MKAV] .....                                                      | 30        |
| 89  | 6.1.3                         | Default configuration .....                                                                    | 30        |
| 90  | 6.1.3.1                       | Assessment criteria for [SDC-FRM] .....                                                        | 30        |
| 91  | 6.1.4                         | Authentication and access control mechanisms .....                                             | 31        |
| 92  | 6.1.4.1                       | Assessment criteria for [ACM-FH] .....                                                         | 31        |
| 93  | 6.1.4.2                       | Assessment criteria for [AUM-FH] .....                                                         | 32        |
| 94  | 6.1.4.3                       | Assessment criteria for [AUTHZ-LP] .....                                                       | 33        |
| 95  | 6.1.4.4                       | Assessment criteria for [AUTHZ-R] .....                                                        | 34        |
| 96  | 6.1.5                         | Integrity protection .....                                                                     | 34        |
| 97  | 6.1.6                         | Confidentiality protection .....                                                               | 34        |
| 98  | 6.1.7                         | Data minimization .....                                                                        | 34        |
| 99  | 6.1.7.1                       | Assessment criteria for [DMIN-DJST] .....                                                      | 34        |
| 100 | 6.1.8                         | Availability protection .....                                                                  | 36        |
| 101 | 6.1.8.1                       | Assessment criteria for [AVAI-TIME-RECO-POW] .....                                             | 36        |
| 102 | 6.1.8.2                       | Assessment criteria for [AVAI-TIME-NETW] .....                                                 | 37        |
| 103 | 6.1.9                         | Impact minimization .....                                                                      | 39        |
| 104 | 6.1.10                        | Limit attack surface .....                                                                     | 39        |
| 105 | 6.1.10.1                      | Assessment criteria for [LAS-SBOOT] .....                                                      | 39        |
| 106 | 6.1.11                        | Logging and monitoring mechanisms .....                                                        | 40        |
| 107 | 6.1.12                        | Deletion mechanisms .....                                                                      | 40        |
| 108 | 6.1.13                        | Other product's technical requirements specifications .....                                    | 40        |
| 109 | 6.2                           | Assessment criteria for vulnerability handling activities related to the product .....         | 40        |
| 110 | <b>Annex A (informative):</b> | <b>Relationship between the present document and the requirements of</b>                       |           |
| 111 |                               | <b>EU Regulation 2024/2847 .....</b>                                                           | <b>41</b> |
| 112 | <b>Annex B (informative):</b> | <b>Guidance for the application of the present document .....</b>                              | <b>46</b> |

|     |                               |                                                                                                      |           |
|-----|-------------------------------|------------------------------------------------------------------------------------------------------|-----------|
| 113 | <b>Annex C (informative):</b> | <b>Information on the methodology for the assessment of cybersecurity</b>                            |           |
| 114 |                               | <b>risks used to develop the present document .....</b>                                              | <b>49</b> |
| 115 | C.1                           | Guidance for determining impact classes.....                                                         | 49        |
| 116 | C.1.1                         | General.....                                                                                         | 49        |
| 117 | C.1.2                         | Confidential data.....                                                                               | 49        |
| 118 | C.1.3                         | Loss sensitive data .....                                                                            | 49        |
| 119 | C.1.4                         | Time sensitive data and time sensitive function .....                                                | 50        |
| 120 | C.1.5                         | Integrity relevant data and integrity relevant function .....                                        | 50        |
| 121 | <b>Annex D (normative):</b>   | <b>Relationship between specific data and functions assets covered by</b>                            |           |
| 122 |                               | <b>the present document to impact classes for generic asset categories .....</b>                     | <b>52</b> |
| 123 | D.1                           | Identifier.....                                                                                      | 52        |
| 124 | D.2                           | Data assets .....                                                                                    | 53        |
| 125 | D.3                           | Function assets .....                                                                                | 54        |
| 126 | D.3.1                         | Functions whose use can cause harm.....                                                              | 54        |
| 127 | <b>Annex E (normative):</b>   | <b>Protection measures.....</b>                                                                      | <b>56</b> |
| 128 | E.1                           | Identifier.....                                                                                      | 56        |
| 129 | E.2                           | access control mechanism's strength .....                                                            | 57        |
| 130 | E.3                           | authentication mechanism strength .....                                                              | 57        |
| 131 | E.3.1                         | AUM-FH Authentication for functions whose use can cause harm.....                                    | 57        |
| 132 | E.3.1.1                       | General .....                                                                                        | 57        |
| 133 | E.3.1.2                       | Authentication strength level basic .....                                                            | 57        |
| 134 | E.3.1.3                       | Authentication strength level normal .....                                                           | 57        |
| 135 | E.3.1.4                       | Authentication strength level enhanced.....                                                          | 57        |
| 136 | E.3.1.5                       | Authentication strength level strong.....                                                            | 58        |
| 137 | E.3.2                         | Assessment for authentication mechanism strength .....                                               | 58        |
| 138 | E.3.2.1                       | Assessment criteria regarding the protection against limited presentation attacks.....               | 58        |
| 139 | E.3.2.2                       | Assessment criteria regarding the protection against targeted presentation attacks .....             | 59        |
| 140 | E.3.2.3                       | Assessment criteria regarding the protection against elaborate presentation attacks .....            | 59        |
| 141 | E.3.2.4                       | Assessment criteria regarding the protection against limited brute force attacks.....                | 60        |
| 142 | E.3.2.5                       | Assessment criteria regarding the protection against targeted brute force attacks .....              | 61        |
| 143 | E.3.2.6                       | Assessment criteria regarding the protection against automated brute force attacks .....             | 61        |
| 144 | E.3.2.7                       | Assessment criteria regarding the protection against presentation attacks.....                       | 62        |
| 145 | E.3.2.8                       | Assessment criteria regarding the protection against elaborate brute force attacks .....             | 63        |
| 146 | E.3.2.9                       | Assessment criteria regarding the protection against automated security token spoofing attacks ..... | 63        |
| 147 | E.3.2.10                      | Assessment criteria regarding the protection against targeted security token spoofing attacks .....  | 64        |
| 148 | E.3.2.11                      | Assessment criteria regarding the protection against elaborate security token spoofing attacks ..... | 65        |
| 149 | E.3.2.12                      | Assessment criteria regarding the protection against replay attacks .....                            | 65        |
| 150 | E.3.2.13                      | Assessment criteria regarding the protection against PitM attacks .....                              | 66        |
| 151 | E.4                           | confidentiality protection strength.....                                                             | 67        |
| 152 | E.4.1                         | CONF-SSM Confidentiality protecting persistent storage for confidential data .....                   | 67        |
| 153 | E.4.1.1                       | General .....                                                                                        | 67        |
| 154 | E.4.1.2                       | confidential persistent storage strength level basic .....                                           | 67        |
| 155 | E.4.1.3                       | confidential persistent storage strength level normal .....                                          | 67        |
| 156 | E.4.1.4                       | confidential persistent storage strength level enhanced .....                                        | 67        |
| 157 | E.4.1.5                       | confidential persistent storage strength level strong.....                                           | 67        |
| 158 | E.5                           | confidentiality protection strength.....                                                             | 67        |
| 159 | E.5.1                         | CONF-COM Communication of confidential data.....                                                     | 67        |
| 160 | E.5.1.1                       | General .....                                                                                        | 67        |
| 161 | E.5.1.2                       | Communication of confidential data protection strength level basic .....                             | 67        |
| 162 | E.5.1.3                       | Communication of confidential data protection strength level normal .....                            | 68        |
| 163 | E.5.1.4                       | Communication of confidential data protection strength level enhanced.....                           | 68        |
| 164 | E.5.1.5                       | Communication of confidential data protect ion strength level strong.....                            | 68        |
| 165 | E.6                           | Integrity protection strength.....                                                                   | 68        |

|     |                               |                                                                                   |           |
|-----|-------------------------------|-----------------------------------------------------------------------------------|-----------|
| 166 | E.6.1                         | INT-SWPCK Software package verification.....                                      | 68        |
| 167 | E.6.1.1                       | General .....                                                                     | 68        |
| 168 | E.6.1.2                       | Software package integrity verification strength level basic .....                | 69        |
| 169 | E.6.1.3                       | Software package integrity verification strength level normal .....               | 69        |
| 170 | E.6.1.4                       | Software package integrity verification strength level enhanced .....             | 69        |
| 171 | E.6.2                         | INT-COM Communication of integrity relevant data .....                            | 69        |
| 172 | E.6.2.1                       | General .....                                                                     | 69        |
| 173 | E.6.2.2                       | Communication of integrity relevant data protection strength level basic .....    | 69        |
| 174 | E.6.2.3                       | Communication of integrity relevant data protection strength level normal .....   | 69        |
| 175 | E.6.2.4                       | Communication of integrity relevant data protection strength level enhanced ..... | 70        |
| 176 | E.6.2.5                       | Communication of integrity relevant data protection strength level strong .....   | 70        |
| 177 | <b>Annex F (informative):</b> | <b>Relationship between the present document and the covered/not</b>              |           |
| 178 |                               | <b>covered cybersecurity risks.....</b>                                           | <b>71</b> |
| 179 | <b>Annex G (informative):</b> | <b>Relationship between the present document and ETSI EN 303 645/</b>             |           |
| 180 |                               | <b>ETSI TS 103 701 .....</b>                                                      | <b>74</b> |
| 181 | History .....                 |                                                                                   | 75        |
| 182 |                               |                                                                                   |           |
| 183 |                               |                                                                                   |           |

## Intellectual Property Rights

### Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

### Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

**DECT™**, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

## Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

| Proposed national transposition dates                                                  |                                 |
|----------------------------------------------------------------------------------------|---------------------------------|
| Date of latest announcement of this EN (doa):                                          | 3 months after ETSI publication |
| Date of latest publication of new National Standard or endorsement of this EN (dop/e): | 6 months after doa              |
| Date of withdrawal of any conflicting National Standard (dow):                         | 18 months after doa             |

---

## Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.



# 1 Scope

The present document specifies vulnerability handling activities, technical characteristics and corresponding assessment criteria for internet connected toys related to cybersecurity. Internet connected toys:

- are specified within the "technical description" of the "category of product" number "18." by Regulation (EU) 2025/2392 [i.2]; and
- are only covered within the product context described in clause 4.

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1] under the conditions identified in annex A.

## 2 References

### 2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- |     |                                                                                                                                                                                       |
|-----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [1] | CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3): "Cybersecurity requirements for products with digital elements - Vulnerability Handling".                                             |
| [2] | Agreed Cryptographic Mechanisms: "European Union Agency for Cybersecurity, European Cybersecurity Certification Group - Sub-group on Cryptography - Agreed Cryptographic Mechanisms". |

### 2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

- |       |                                                                                                                                                                                                                                                                                                          |
|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [i.1] | <a href="#">Regulation (EU) 2024/2847</a> of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act). |
| [i.2] | <a href="#">Commission Implementing Regulation (EU) 2025/2392</a> of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.                       |

|     |       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 263 | [i.3] | <a href="#">Standardisation request M/606 - C(2025)618</a> : "Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)". |
| 270 | [i.4] | CEN/CLC JT013095:2026 (CEN/CLC prEN 40000-1-1): "Cybersecurity requirements for products with digital elements – Vocabulary".                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| 272 | [i.5] | ETSI EN 304 623 v1.1.1 (2026): "Cyber Security (CYBER); CRA; Cybersecurity requirements for boot managers".                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

## 274 3 Definition of terms, symbols and abbreviations

### 275 3.1 Terms

276 For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 [i.1], CEN/CLC  
277 JT013095:2026 (CEN/CLC prEN 40000-1-1) [i.4] and the following apply:

#### 278 ARCHITECTURE RELATED TERMS

279 **application software**: software designed to perform specific consumer- or ICT-oriented functional tasks on a device,  
280 operating on top of the core software, and without direct responsibility for hardware initialization or fundamental  
281 system control

282 **EXAMPLE:** A mobile app, desktop software or parts of MP's embedded software that implements essential  
283 functionalities.

284 **NOTE:** Application software typically uses APIs provided by core software.

285 **core software**: any software that abstracts hardware, manages hardware resources and provides interfaces for other  
286 software to interact with each other or the core software

287 **main product**: ICT excluding its RDPS

288 **EXAMPLE:** A physical MP's operating system, hardware abstraction layer or APIs for application software

#### 289 GENERAL DATA RELATED TERMS

290 **data**: information in digital form

291 **location data**: data containing geographical information

292 **public data**: data from publicly accessible sources

293 **user data**: data provided by a consumer

#### 294 VERTICAL SPECIFIC DATA RELATED TERMS

295 **void**: void

#### 296 GENERAL FUNCTIONALITY RELATED TERMS

297 **authorization policy**: policy that describes the access rights of entities on ICT's data and functions

298 **function output**: output of RDPSs' or MP's functions that is:

- 299 • a modification or creation of ICTs' data or functions;
- 300 • information intended to inform human users;

- information intended to inform or control devices or services; or
- an action on the physical operational environment

**function trigger input:** input to the RDPSs' or MP's functions provided by:

- human users;
- devices or services; or
- the physical operational environment

## VERTICAL SPECIFIC FUNCTIONALITY RELATED TERMS

**social interactive function:** ICT function which provides function output as reaction to function trigger input related to social interactions

## GENERAL DATA ASSETS

**audio input data:** data asset that represents audio information captured by the ICT

**authorization policy data:** data asset that contains an authorization policy

EXAMPLE: Assignment of privileges to consumers.

**ICT state data:** data asset that contains ICT state information

**network status data:** data asset that describes MPs' or RDPSs' network connections status

**software package:** data asset that contains software intended to be installed on the ICT

**video input data:** data asset that represents video information captured by the ICT

EXAMPLE: Video or picture recordings processed (including storage) on the ICT.

## VERTICAL SPECIFIC DATA ASSETS

**emergency location sharing data:** MP position data that is intended to support in an emergency situation

**geofence location data:** location data that describes a region for the MP determining the ICT's behaviour

**MP position data:** location data describing the position of the MP

**social interactive data:** data containing information related to child interactions with social features of the toy or other entities

EXAMPLE: Communication data such as speech, text, image and video interaction, consumer-generated content, consumed media content such as educational material, music, audiobooks, videos.

NOTE: Refers to all data generated, exchanged or processed through interactive and communicative functionalities between the child, the connected toy and other participants (such as parents, peers or online services).

## GENERAL FUNCTION ASSETS

**access control mechanism:** ICT function that enforces an authorization policy

**audio input function:** ICT function that converts audio signals into data

**audio output function:** ICT function that converts data into audio signals

**authentication mechanism:** ICT function that verifies an entity's claim

**bootloader function:** ICT function that initiates the execution of other core software at startup

**configuration function:** ICT function that allows to change the configuration of ICT's functions

337 **connection function:** ICT function that is used for testing or establishing communication capability via machine  
338 interface

339       EXAMPLE:       ICMP, DHCP Discovery.

340       NOTE:       In this context, establishing communication means communication without user data and without  
341 authentication of the communication partner for the purpose of establishment of a connection.

342 **factory reset function:** ICT function that removes all user data and sets the MP in a factory default state, potentially  
343 keeping software updates

344 **input sanitization mechanism:** ICT function that scans function input data and removes or alters parts, that can lead to  
345 incidents based on a function specific pattern

346 **input validation mechanism:** ICT function that rejects input data if it does not meet an accepted pattern

347 **logging mechanism:** ICT function that logs events

348 **notification mechanism:** ICT function that notifies entities on certain events

349 **real-time service or clock:** service or function that provides real time information

350 **software package verification mechanism:** ICT function that verifies the integrity and authenticity of software  
351 packages

352 **software update mechanism:** ICT function that allows to change the ICT's software

353 **time service or function:** service or function that provides time information

354 **video input function:** ICT function that converts video signals into data

355 **video output function:** ICT function that converts data into video signals

## 356 VERTICAL SPECIFIC FUNCTION ASSETS

357 **emergency location function:** ICT function which provides MP position data in case of an emergency

358 **geo fencing notification function:** ICT function which triggers a notification when the MP leaves or enters a region  
359 defined via geofence location data

360 **location sharing function:** ICT function that shares MP position data

361 **parental control function:** ICT function that enables parents or guardians to control:

- 362       • access rights of children on the ICT;
- 363       • sources where children can access external content from; or
- 364       • persons that can communicate with the child

365 **positioning function:** ICT function that determines the MP's position

## 366 INTERFACES

367 **human interface:** interface that is intended to be used by human

368 **interface:** shared boundary across which the ICT exchanges information

369 **logical human interface:** interface that is a human interface and a logical interface

370 **logical interface:** interface that does not exist in hardware and can only be used by using another device or a physical  
371 interface of a product with digital elements

372 **machine interface:** interface that is intended to be used for machine-to-machine communication

373 **physical human interface:** interface that is a human interface and a physical interface

374 **physical interface:** interface that is part of the hardware of a ICT

## COMMUNICATION TYPES

**adjacent communication:** public communication limited to a logically adjacent topology or ingoing/outgoing communication to private networks

**local communication:** ingoing/outgoing communication which requires physical access to a communication partner's interface or proximity of the communication partner to the product

**physical communication:** communication that requires physical interchange with the communication partner's hardware or the hardware the communication partner runs on

**public communication:** ingoing/outgoing communication to public networks

**strict local communication:** ingoing/outgoing communication which requires physical presence at a communication partner's interface

## OPERATIONAL ENVIRONMENTS

**confined operational environment:** physical operational environment, where the geographical location is confined to a specific area

**fully controlled physical operational environment:** physical operational environment, where physical access is fully controlled by the guardian or trusted persons

EXAMPLE: Private house or apartment.

**logical operational environment:** operational environment describing the accessibility via logical interfaces

**mobile operational environment:** physical operational environment, where the geographical location is changing during operation and not confined to a specific area

NOTE: Physical operational environment of smartphones and wearables.

**partially controlled physical operational environment:** physical operational environment, that is not a fully controlled physical operational environment and either under the control of a limited set of persons or located in an area where untrusted physical access is suspicious

EXAMPLE: Shared area in a house with different apartments or private property where public access is not intended.

**physical operational environment:** operational environment determining the physical accessibility of an architectural component

**stationary operational environment:** physical operational environment, where the geographical location is fixed

**uncontrolled physical operational environment:** physical operational environment, where physical access control on arbitrary untrusted entities cannot be ensured for prolonged time periods and where untrusted physical access is not necessarily suspicious.

EXAMPLE: Areas intended for public access.

## GENERIC ASSET CATEGORIES

**confidential data:** data asset, whose disclosure can have a negative impact

**data asset:** asset, that is data processed by the ICT

**function asset:** asset, that is a function of the ICT

**function, whose use can cause harm:** function asset that is:

- a function, whose use can impact the availability of other devices, services or networks;
- a function, whose use can impact the safety or privacy of human entities;
- a function, which can communicate confidential data;

- 415 • a function, which can communicate integrity relevant data;
  - 416 • a function, which can modify integrity relevant data; or
  - 417 • a function, which can modify integrity relevant functions
- 418 **integrity relevant data:** data asset, whose tampering can have a negative impact
- 419 **integrity relevant function:** function asset, whose tampering can have a negative impact
- 420 **loss sensitive data:** data asset, whose permanent loss has a negative impact
- 421 **time sensitive data:** data asset, where a time delay in availability has a negative impact
- 422 **time sensitive function:** function asset, where a time delay in availability has a negative impact
- 423 **USERS**
- 424 **child:** human entity under 14 years of age
- 425 **consumer:** natural entity that directly interacts with the ICT including guardian or child
- 426 **guardian:** natural or legal entity with responsibility for the child
- 427 NOTE: This includes also parents.

## 428 3.2 Symbols

429 Void.

## 430 3.3 Abbreviations

431 For the purposes of the present document, the following abbreviations apply:

|     |      |                                     |
|-----|------|-------------------------------------|
| 432 | DHCP | Dynamic Host Configuration Protocol |
| 433 | GUI  | Graphical User Interface            |
| 434 | ICMP | Internet Control Message Protocol   |
| 435 | ICT  | Internet Connected Toy              |
| 436 | MP   | Main Product                        |
| 437 | RDPS | Remote Data Processing Solution     |
| 438 | SIF  | Social Interactive Function         |

---

## 439 4 Product context

### 440 4.1 Product functions

441 The present document addresses the following essential functionalities of ICT:

- 442 • **SIFs** that might make use of the following functions:
  - 443 - audio input function
  - 444 - video input function
  - 445 - audio output function
  - 446 - video output function
  - 447 - ICT function which can communicate ICT data
  - 448 - ICT function which can modify ICT data

- 449       •    positioning functions
- 450       •    location sharing functions
- 451       •    emergency location functions
- 452       •    geo fencing notification functions
- 453       •    parental control functions

454   The present document addresses the following supporting functionalities of ICT:

- 455       •    configuration function
- 456       •    software update mechanism
- 457       •    monitoring mechanism
- 458       •    notification mechanism
- 459       •    logging mechanism
- 460       •    access control mechanism
- 461       •    authentication mechanism
- 462       •    factory reset function
- 463       •    integrity protecting communication mechanism
- 464       •    confidentiality protecting communication mechanism
- 465       •    integrity protecting secure storage mechanism
- 466       •    confidentiality protecting secure storage mechanism
- 467       •    deletion mechanism
- 468       •    onboarding mechanism
- 469       •    input sanitization mechanism
- 470       •    input validation mechanism
- 471       •    software package verification mechanism
- 472       •    bootloader function
- 473       •    time service or function
- 474       •    real-time service or clock

475   The essential and supporting functionalities might process the following data assets:

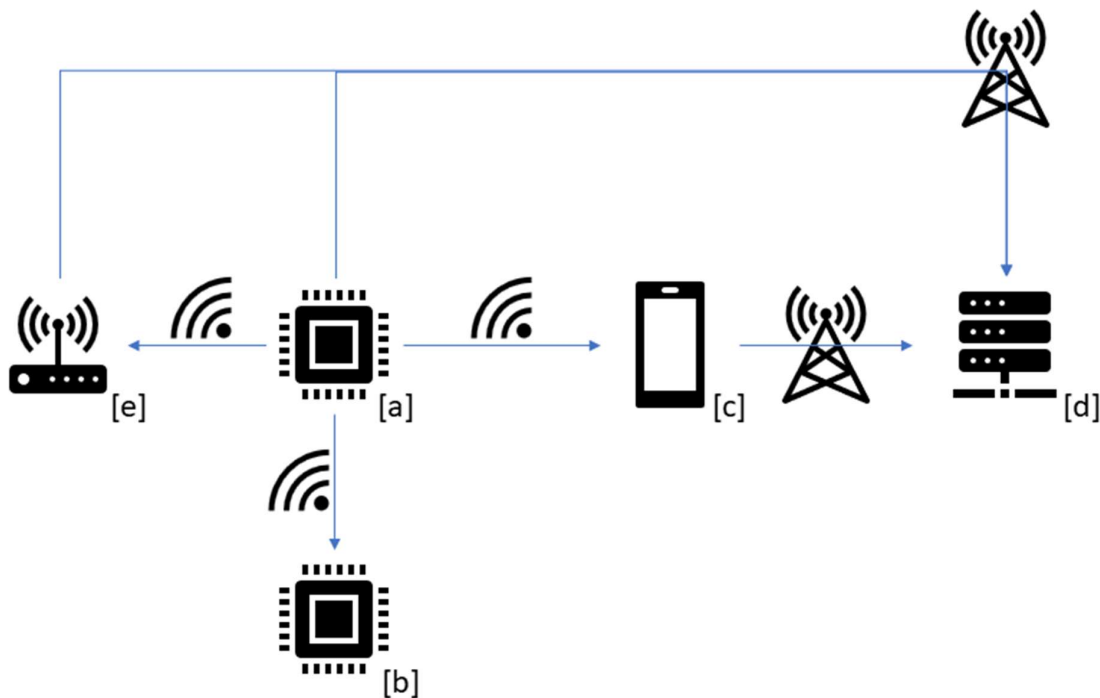
- 476       •    audio input data
- 477       •    video input data
- 478       •    network status data
- 479       •    authorization policy data
- 480       •    ICT state data
- 481       •    logging data
- 482       •    software package

- 483 • MP position data
- 484 • emergency location sharing data
- 485 • geofence location data
- 486 • social interactive data

## 487 4.2 Product Architecture

488 The architecture of a ICT consists of the following architectural components:

- 489 • Hardware MP including software
- 490 • (optional) App RDPS
- 491 • (optional) Cloud RDPS



492

493 **Figure 1: Architectural Components and possible connections between them**

494 Exemplary architectural components and possible connections between them are shown in figure 1. The following  
 495 components are shown in the figure:

- 496 a) MP
- 497 b) Another ICT's MP
- 498 c) App RDPS
- 499 d) Cloud RDPS
- 500 e) A gateway

501 NOTE: Not all subsets of connected components necessarily correspond to the scope of the present document (see  
 502 clause 1).



## 4.3 Operational Environment

The present document addresses the following operational environments of ICT.

For the logical operational environment, the following digital communication types are addressed for any architectural component of the ICT:

- **public communication** - COM.Public
- **adjacent communication** - COM.Adjacent
- **local communication** - COM.Local
- **strict local communication** - COM.StrictLocal

For the physical operational environment, the following environments are addressed for MPs:

- **fully controlled physical operational environment** - POE.FullyControlled
- **partially controlled physical operational environment** - POE.PartiallyControlled
- **mobile operational environment** - POE.Mobile

For the physical operational environment, the following environments are addressed for App RDPSs:

- App RDPS which run on a host device that is intended or reasonably foreseen to be operated in a:
  - **fully controlled physical operational environment** - POE.FullyControlled
  - **partially controlled physical operational environment** - POE.PartiallyControlled
  - **mobile operational environment** - POE.Mobile

For the physical operational environment, the following environments are addressed for Cloud RDPSs:

- Cloud RDPS runs on a host device that is intended or reasonably foreseen to be operated in a
  - **fully controlled physical operational environment** - POE.FullyControlled

## 4.4 Interface

The present document addresses the following interfaces of ICT:

- **human interface** - IF.Human
- **machine interface** - IF.Machine
- **logical interface** - IF.Logical
- **physical interface** - IF.Physical

## 4.5 Distribution of security functions

The present document addresses the distribution of security functions among the ICT and other products with digital elements in the ICT's context (e.g. host devices for ICT's architectural components that are software) by the following expressions used to formulate the technical requirements specifications in clause [5.1](#).

"The ICT shall [...] use [some expression related to security functions]" means:

- the ICT itself provides those security functions which are always used; or
- other products with digital elements in the ICT's context provide those security functions which are always used by the ICT.

"The ICT shall [...] support [some expression related to security functions]" means:

- the ICT itself provides those security functions; or
- other products with digital elements in the ICT's context provide those security functions.

"The ICT shall [...] provide [some expression related to security functions]" means that the ICT itself provides those security functions.

Situations where the ICT itself does not provide security functions that are required to be used or supported by the ICT and other products with digital elements in the ICT's context do not provide those security functions, are addressed in the requirement [USERNOT-NOSECFUC] in clause [5.1.12](#).

## 4.6 Users

The present document addresses the following users of ICT:

- Consumers for private usage
- Manufactures for integration in other products with digital elements intended for consumers

## 4.7 Use cases

### 4.7.1 General

The present document addresses all use cases that can be constructed by the previous elements of clause [4](#).

### 4.7.2 Use case profiles

In order to classify use cases and to define security profiles the following use case profiles are defined. Those definitions make use of impact classes of functions. The functions covered by the present document are provided in clause [4.1](#), their impact classes in annex [D](#).

#### **Use case profile for low impact functions**

The use case profile for low impact functions bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAL.TIME) of a ICT's function falls under IMP.Low.

#### **Use case profile for medium impact functions**

The use case profile for medium impact functions bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAL.TIME) of a ICT's function falls under IMP.Medium.

#### **Use case profile for high impact functions**

The use case profile for high impact functions bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAL.TIME) of a ICT's function falls under IMP.High.

## 4.8 Security Profiles

Based on the use case profiles defined in clause [4.7.2](#) the following security profiles with assigned requirements in table [1](#) are defined:

- security profile for low impact functions
- security profile for medium impact functions
- security profile for high impact functions

571

Table 1: Security profiles with corresponding requirements

| Requirement           | Security profile for |                         |                       |
|-----------------------|----------------------|-------------------------|-----------------------|
|                       | Low impact functions | Medium impact functions | High impact functions |
| [NKEV-MKAV]           | X                    | X                       | X                     |
| [NKEV-SUM-SUPPORT]    | X                    | X                       | X                     |
| [NKEV-SUM-PROVIDE]    | X                    | X                       | X                     |
| [NKEV-SUM-AUTO]       | X                    | X                       | X                     |
| [NKEV-SUM-NOTIF]      | X                    | X                       | X                     |
| [SDC-AUM-FH]          | X                    | X                       | X                     |
| [SDC-SUM-AUTO]        | X                    | X                       | X                     |
| [SDC-SUM-NOTIF]       | X                    | X                       | X                     |
| [SDC-FRM]             | X                    | X                       | X                     |
| [SDC-PARCONT]         | X                    | X                       | X                     |
| [ACM-FH]              | X                    | X                       | X                     |
| [AUM-FH]              | X                    | X                       | X                     |
| [AUTHZ-LP]            | X                    | X                       | X                     |
| [AUTHZ-R]             | X                    | X                       | X                     |
| [AUTHZ-PC]            | X                    | X                       | X                     |
| [INT-SWPCK]           | X                    | X                       | X                     |
| [INT-COM]             | X                    | X                       | X                     |
| [CONF-SSM]            | X                    | X                       | X                     |
| [CONF-COM]            | X                    | X                       | X                     |
| [AVAI-TIME-RECO-POW]  | X                    | X                       | X                     |
| [AVAI-TIME-NETW]      | X                    | X                       | X                     |
| [AVAI-TIME-RECO-NETW] | X                    | X                       | X                     |
| [AVAI-TIME-OUTA-NOT]  |                      | X                       | X                     |
| [AVAI-TIME-PREV-NOT]  |                      |                         | X                     |
| [AVAI-TIME-NET-PRIO]  |                      | X                       | X                     |
| [AVAI-TIME-RES-PRIO]  |                      | X                       | X                     |
| [AVAI-TIME-IMP-AMP]   |                      | X                       | X                     |
| [AVAI-TIME-DOS-RATE]  |                      |                         | X                     |
| [AVAI-SUM-SCHEDULE]   |                      | X                       | X                     |
| [LAS-INVAL]           | X                    | X                       | X                     |
| [LAS-INSAN]           | X                    | X                       | X                     |
| [LAS-PHY-INF]         | X                    | X                       | X                     |
| [LAS-LOGIC-INF]       | X                    | X                       | X                     |
| [LAS-APP]             | X                    | X                       | X                     |
| [LAS-SBOOT]           |                      |                         | X                     |
| [USERNOT-NOSECFUC]    | X                    | X                       | X                     |
| [PARCONT]             | X                    | X                       | X                     |
| [DMIN-DJST]           | X                    | X                       | X                     |
| [LOG-LOW]             | X                    |                         |                       |
| [LOG-MEDIUM]          |                      | X                       |                       |
| [LOG-HIGH]            |                      |                         | X                     |
| [LOG-TIME]            | X                    | X                       |                       |
| [LOG-TIME-HIGH]       |                      |                         | X                     |
| [LOG-STORAGE]         |                      | X                       | X                     |
| [LOG-BACKUP]          |                      |                         | X                     |

572

## 5 Requirements specifications

### 5.1 Product's technical requirements specifications

#### 5.1.1 Known exploitable vulnerabilities

##### 5.1.1.1 [NKEV-MKAV] No known exploitable vulnerabilities

In accordance with the vulnerability handling specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1], the ICT shall prior to making available on the market have no insufficiently mitigated known exploitable vulnerabilities.

NOTE 1: The known exploitable vulnerabilities that occur after making the ICT available on the market are subject to the vulnerability handling in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1].

NOTE 2: Typically, products are supplied with all necessary security updates during commissioning.

##### 5.1.1.2 [NKEV-SUM-SUPPORT] Secure software update mechanism

The ICT shall support software update mechanisms, that allow to update every part of the ICT's software, except for parts of the ICT's software, that are immutable due to technical reasons.

EXAMPLE: A mobile RDPS is installed on a device that supports updating the mobile RDPS (e.g. via app-stores)

##### 5.1.1.3 [NKEV-SUM-PROVIDE] Secure software update mechanism for core components

All architectural components of the ICT that include core software shall provide software update mechanisms, that allow to update every part of the architectural components software, except for parts of the architectural components software, that are immutable due to security.

NOTE: A mobile application typically does not need to provide an update mechanism.

##### 5.1.1.4 [NKEV-SUM-AUTO] Automated security updates

The ICT shall support the automated update of its software.

##### 5.1.1.5 [NKEV-SUM-NOTIF] Update notifications

The ICT shall support the automated notification of its consumers, when updates of its software are available.

### 5.1.2 Default configuration

#### 5.1.2.1 [SDC-AUM-FH] Default configuration of authentication for functions whose use can cause harm

The ICT shall by default be configured to use authentication mechanisms that meet:

- the authentication mechanisms strengths specified in clause [E.3.1](#); and
- the minimal authentication mechanisms' strength determined by table [3](#).

except for connection functions.

NOTE: The support of authentication for functions whose use can cause harm is addressed in [AUM-FH].

### 5.1.2.2 [SDC-SUM-AUTO] Default configuration of automated security updates

The ICT shall by default be configured to use automated software update mechanisms for its software.

NOTE: The support of automated security updates is addressed in [NKEV-SUM-AUTO].

### 5.1.2.3 [SDC-SUM-NOTIF] Default configuration of update notifications

The ICT shall by default be configured to use automated notification of its consumers, when updates of the ICT's software are available.

NOTE: The support of update notification is addressed in [NKEV-SUM-NOTIF].

### 5.1.2.4 [SDC-FRM] Factory reset to restore the default state

The ICT shall provide a factory reset mechanism that allows a guardian to restore the default state, including the deletion of all user data, installed applications, and configurations deviating from the default state.

NOTE 1: It is also possible that the factory reset will delete the installed security updates if these are installed automatically or on request when the device is commissioned again.

NOTE 2: ANNEX II 8. d) of Regulation (EU) 2024/2847 [i.1] contains legal obligations on how consumers of the ICT are informed about secure decommissioning of the ICT.

### 5.1.2.5 [SDC-PARCONT] Default configuration for parental control

The ICT shall by default be configured to:

- deny children access to security relevant configuration function;
- restrict the sources where children can access external content from to trusted sources; and
- restrict entities that can communicate with the child to trusted entities.

EXAMPLE 1: The ICT is used by the child without any prior configuration by a guardian. Access to communication with others and external data is not possible and cannot be enabled by the child.

EXAMPLE 2: The ICT is initially configured by the guardian. The guardian determines which external content the child is allowed to access, with the ICT offering different levels based on the child's age. The trusted entities with which the child is allowed to communicate are also determined by a guardian.

NOTE: The requirement [SDC-PARCONT] addresses the default configuration of parental control functions. The support of parental control functions is addressed in [PARCONT].

## 5.1.3 Authentication and access control mechanisms

### 5.1.3.1 [ACM-FH] Access control for functions whose use can cause harm

The ICT shall use access control mechanisms to control entities' use of functions whose use can cause harm, where the applicability of this requirement is determined by table 2 except for connection functions.

**Table 2: Assignment for access control mechanisms**

|                                                                                                 |                                      |                         | Impact class for function, whose use can cause harm |               |               |
|-------------------------------------------------------------------------------------------------|--------------------------------------|-------------------------|-----------------------------------------------------|---------------|---------------|
|                                                                                                 |                                      |                         | IMP.FH.Low                                          | IMP.FH.Medium | IMP.FH.High   |
| Attack Surface determined by COM, IF and POE of RDPS or MP that receives function trigger input | COM.StrictLocal via IF.Any           | POE.FullyControlled     | N/A                                                 | N/A           | applicable[*] |
|                                                                                                 |                                      | POE.PartiallyControlled | N/A                                                 | applicable[*] | applicable[*] |
|                                                                                                 |                                      | POE.Mobile              | applicable[*]                                       | applicable[*] | applicable[*] |
|                                                                                                 | COM.Local via IF.HumanPhysical       | POE.FullyControlled     | N/A                                                 | applicable    | applicable    |
|                                                                                                 |                                      | POE.PartiallyControlled | applicable                                          | applicable    | applicable    |
|                                                                                                 |                                      | POE.Mobile              | applicable                                          | applicable    | applicable    |
|                                                                                                 | COM.Local via a non-IF.HumanPhysical | POE.Any                 | applicable                                          | applicable    | applicable    |
|                                                                                                 | COM.Adjacent via IF.Any              |                         | applicable                                          | applicable    | applicable    |
|                                                                                                 | COM.Public via IF.Any                |                         | applicable                                          | applicable    | applicable    |

For protection measures that are labelled with [\*] it is not required that the ICT uses access control mechanisms for its following functions:

- factory reset function
- functions configured by parental control function

### 5.1.3.2 [PARCONT] Support of parental control

The ICT shall support parental control functions, covering the parents' or guardians' control of:

- access rights on the ICT of children;
- (if the ICT allows children to access external content), the sources where children are allowed to access external content from; and
- (if the ICT allows children to communicate with other persons), the persons that are allowed to communicate with children.

### 5.1.3.3 [AUM-FH] Authentication for functions whose use can cause harm

The ICT shall support authentication mechanisms, to authenticate entities using functions whose use can cause harm before generating function output, where:

- the authentication mechanisms strengths' are specified in clause [E.3.1](#); and
- the minimal required authentication strength is determined by table [3](#),

except for connection functions.

**Table 3: Assignment for authentication mechanisms strengths**

|                                                                                                 |                                      |                         | Impact class for function, whose use can cause harm |                |                  |
|-------------------------------------------------------------------------------------------------|--------------------------------------|-------------------------|-----------------------------------------------------|----------------|------------------|
|                                                                                                 |                                      |                         | IMP.FH.Low                                          | IMP.FH.Medium  | IMP.FH.High      |
| Attack Surface determined by COM, IF and POE of RDPS or MP that receives function trigger input | COM.StrictLocal via IF.Any           | POE.FullyControlled     | N/A                                                 | N/A            | AUTH.Normal[*]   |
|                                                                                                 |                                      | POE.PartiallyControlled | N/A                                                 | AUTH.Basic[*]  | AUTH.Normal[*]   |
|                                                                                                 |                                      | POE.Mobile              | AUTH.Basic[*]                                       | AUTH.Normal[*] | AUTH.Enhanced[*] |
|                                                                                                 | COM.Local via IF.HumanPhysical       | POE.FullyControlled     | N/A                                                 | AUTH.Basic     | AUTH.Normal      |
|                                                                                                 |                                      | POE.PartiallyControlled | AUTH.Basic                                          | AUTH.Normal    | AUTH.Enhanced    |
|                                                                                                 |                                      | POE.Mobile              | AUTH.Basic                                          | AUTH.Normal    | AUTH.Enhanced    |
|                                                                                                 | COM.Local via a non-IF.HumanPhysical | POE.Any                 | AUTH.Normal                                         | AUTH.Normal    | AUTH.Enhanced    |
|                                                                                                 | COM.Adjacent via IF.Any              |                         | AUTH.Normal                                         | AUTH.Normal    | AUTH.Enhanced    |
|                                                                                                 | COM.Public via IF.Any                |                         | AUTH.Normal                                         | AUTH.Enhanced  | AUTH.Enhanced    |

For protection measures that are labelled with [1] it is not required that the ICT uses authentication mechanisms for its following functions:

- factory reset function
- functions configured by parental control function

#### 5.1.3.4 [AUTHZ-LP] Least privilege in authorization policies

The ICT shall use an authorization policy that only grants permissions that are necessary for the intended purpose.

EXAMPLE: The child has no permissions to change security relevant configurations, but the guardian has.

#### 5.1.3.5 [AUTHZ-R] Revocability of granted permissions

The ICT shall support the revocation of any permission granted by an authorized entity.

EXAMPLE: An administrative consumer can revoke permissions granted to another consumer.

#### 5.1.3.6 [AUTHZ-PC] Authorization policies for parental control

The ICT shall use an authorization policy that can differentiate between guardian and child.

### 5.1.4 Integrity protection

#### 5.1.4.1 [INT-SWPCK] Software package verification

The ICT shall use software package verification mechanisms to verify the integrity and authenticity of software packages prior to installation where the software package verification mechanism's strength levels are specified in clause [E.6.1](#) and where the minimal software package verification mechanism's strength is determined by table [4](#).

NOTE: The requirement addresses software packages that are updates and new software to be installed.

**Table 4: Assignment of the software package verification mechanism's strength levels for the verification of software packages**

|                                                                                                |                                       | Highest IMP.INT of the ICT's integrity relevant functions |                   |                     |
|------------------------------------------------------------------------------------------------|---------------------------------------|-----------------------------------------------------------|-------------------|---------------------|
|                                                                                                |                                       | IMP.INT.Low                                               | IMP.INT.Medium    | IMP.INT.High        |
| Attack Surface determined by the COM of RDPS or MP over which the software package is received | COM.StrictLocal                       | INT.SW.VER.Basic                                          | INT.SW.VER.Basic  | INT.SW.VER.Basic    |
|                                                                                                | COM.Local, COM.Adjacent or COM.Public | INT.SW.VER.Normal                                         | INT.SW.VER.Normal | INT.SW.VER.Enhanced |

#### 5.1.4.2 [INT-COM] Communication of integrity relevant data

The ICT shall use integrity protecting communication mechanisms to protect the integrity of communicated integrity relevant data, where the corresponding integrity protection measures strengths are specified in clause [E.6.2](#) and the minimal required integrity protection measures' strength are determined by table [5](#).

**Table 5: Assignment of protection mechanisms strength level for the integrity protection of outgoing data and for the integrity verification of incoming data**

|                                                                                                      |                                             |                         | Integrity relevant data impact class |                  |                  |
|------------------------------------------------------------------------------------------------------|---------------------------------------------|-------------------------|--------------------------------------|------------------|------------------|
|                                                                                                      |                                             |                         | IMP.INT.Low                          | IMP.INT.Medium   | IMP.INT.High     |
| Attack Surface determined by COM, IF and POE of RDPS or MP that communicates integrity relevant data | COM.StrictLocal via IF.Machine              | POE.Any                 | INT.COM.Basic                        | INT.COM.Basic    | INT.COM.Basic    |
|                                                                                                      | COM.Local via IF.Machine or IF.HumanLogical | POE.FullyControlled     | INT.COM.Basic                        | INT.COM.Basic    | INT.COM.Normal   |
|                                                                                                      |                                             | POE.PartiallyControlled | INT.COM.Basic                        | INT.COM.Normal   | INT.COM.Enhanced |
|                                                                                                      |                                             | POE.Uncontrolled        | INT.COM.Normal                       | INT.COM.Enhanced | INT.COM.Enhanced |
|                                                                                                      | COM.Adjacent via IF.Any                     | POE.Any                 | INT.COM.Enhanced                     | INT.COM.Enhanced | INT.COM.Enhanced |
|                                                                                                      | COM.Public via IF.Any                       |                         | INT.COM.Enhanced                     | INT.COM.Enhanced | INT.COM.Enhanced |

#### 5.1.5 Confidentiality protection

##### 5.1.5.1 [CONF-SSM] Confidentiality protecting persistent storage for confidential data

The ICT shall use confidentiality protecting secure storage mechanisms for persistently stored confidential data, where the mechanisms' strength are specified in clause [E.4.1](#) and the minimal required mechanisms' strength are determined by table [6](#).



**Table 6: Assignment for confidentiality protecting secure storage mechanisms**

|                                                                                           |                         | Confidentiality impact class for persistently stored confidential data |                   |                   |
|-------------------------------------------------------------------------------------------|-------------------------|------------------------------------------------------------------------|-------------------|-------------------|
|                                                                                           |                         | IMP.CONF.Low                                                           | IMP.CONF.Medium   | IMP.CONF.High     |
| Attack Surface determined by POE of RDPS or MP that persistently stores confidential data | POE.FullyControlled     | N/A                                                                    | N/A               | N/A               |
|                                                                                           | POE.PartiallyControlled | N/A                                                                    | CONF.SSM.Basic[1] | CONF.SSM.Normal   |
|                                                                                           | POE.Mobile              | CONF.SSM.Basic[1]                                                      | CONF.SSM.Normal   | CONF.SSM.Enhanced |

For protection measures labelled with [1], it is not required that the ICT uses confidentiality protecting persistent storage for confidential data for confidential data:

- which is persistently stored on non-removable storage.

### 5.1.5.2 [CONF-COM] Communication of confidential data

The ICT shall use confidentiality protecting communication mechanisms to protect the confidentiality of communicated confidential data, where the corresponding confidentiality protection measures strengths are specified in clause [E.5.1](#) and the minimal required confidentiality protection measures' strength are determined by table [7](#).

**Table 7: Assignment of protection mechanisms strength level for the confidentiality of communicated data**

|                                                                                                |                                             |                         | Confidential data impact class |                   |                   |
|------------------------------------------------------------------------------------------------|---------------------------------------------|-------------------------|--------------------------------|-------------------|-------------------|
|                                                                                                |                                             |                         | IMP.CONF.Low                   | IMP.CONF.Medium   | IMP.CONF.High     |
| Attack Surface determined by COM, IF and POE of RDPS or MP that communicates confidential data | COM.Local via IF.Machine or IF.HumanLogical | POE.FullyControlled     | N/A                            | N/A               | CONF.COM.Normal   |
|                                                                                                |                                             | POE.PartiallyControlled | N/A                            | CONF.COM.Basic    | CONF.COM.Normal   |
|                                                                                                |                                             | POE.Uncontrolled        | CONF.COM.Basic                 | CONF.COM.Normal   | CONF.COM.Enhanced |
|                                                                                                | COM.Adjacent via IF.Any                     | POE.Any                 | CONF.COM.Enhanced              | CONF.COM.Enhanced | CONF.COM.Enhanced |
|                                                                                                | COM.Public via IF.Any                       |                         | CONF.COM.Enhanced              | CONF.COM.Enhanced | CONF.COM.Enhanced |

## 5.1.6 Data minimization

### 5.1.6.1 [DMIN-DJST] Documented justification of processed data

The ICT shall only process confidential data according to its intended purpose.

## 5.1.7 Availability protection

### 5.1.7.1 [AVAI-TIME-RECO-POW] Restoration after loss of power

The MP shall use a mechanism to resume connectivity and functionality in the case of a loss of power as soon as the power supply is restored.

#### 5.1.7.2 [AVAI-TIME-NETW] Local operation

Where network connectivity is not necessary for a time sensitive function to operate, the ICT shall ensure the operability of this function in the case of a loss of network access.

#### 5.1.7.3 [AVAI-TIME-RECO-NETW] Restoration after loss of network connection

The ICT shall use a mechanism to reconnect cleanly after a loss of network connection.

EXAMPLE: A ICT loses connection to the local network as the network is temporarily unavailable. After recognizing the restored network, the ICT reconnects after a randomized delay to reconnect cleanly.

NOTE: *Reconnecting cleanly* normally involves resuming connectivity to network in an expected, operational and stable state and in an orderly fashion taking the capability of the infrastructure into consideration.

#### 5.1.7.4 [AVAI-TIME-OUTA-NOT] Notify non-availability

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the ICT, the ICT shall use a mechanism to warn the guardian before or at least during a IMP.AVAI.TIME.Medium or higher function becomes unavailable due to CPU, memory, power or network limitations.

EXAMPLE 1: A cloud RDPS recognizes a non-availability of its MP and sends a notification to the guardian.

EXAMPLE 2: A ICT with a network-dependend IMP.AVAI.TIME.High function recognizes a low bandwidth and sends a notification to the guardian.

#### 5.1.7.5 [AVAI-TIME-PREV-NOT] Notify upcoming limitation

Where at least one time sensitive function with IMP.AVAI.TIME.High is provided by the ICT, the ICT shall use a mechanism to notify the guardian when the ICT recognizes upcoming resource limitations.

EXAMPLE: A battery powered ICT recognizes low battery and sends a notification to the guardian.

#### 5.1.7.6 [AVAI-TIME-NET-PRIO] Network prioritization

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher with the need of network connectivity for operation is provided by the ICT, the ICT shall use a mechanism to prioritize the execution of these functions in the case of a network resource conflict.

#### 5.1.7.7 [AVAI-TIME-RES-PRIO] Resource prioritization

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the ICT, the ICT shall use a mechanism to prioritize the execution of these functions in the case of a CPU, memory or power resource conflict.

EXAMPLE: The ICT uses the following prioritization in case of resource conflict (high to low priority):

- 1) Time sensitive availability relevant functions
- 2) Authenticated consumer commands
- 3) Background tasks (e.g. logging, updates)

NOTE: At least the following resources can cause a processing resource conflict: CPU, memory, power.

#### 5.1.7.8 [AVAI-TIME-IMP-AMP] Amplification control

Where at least one function, whose use can impact the availability of other devices, services or networks with IMP.FH.DSN.Medium or higher is provided by the ICT, the ICT shall use mechanisms to prevent effective amplification of requests or network traffic of these functions.

747       EXAMPLE:     An ICMP request has an amplification factor of three. Then the response time is artificially  
748                       extended by a factor of tree per destination to have no effective gain in bandwidth.

#### 749   5.1.7.9        [AVAI-TIME-DOS-RATE] Incoming rate limiting

750   Where at least one time sensitive function with IMP.AVAI.TIME.High AND at least one machine interface are  
751   provided by the ICT, the ICT shall use mechanisms to discard packets from a source if it sends an unusually high  
752   number of requests, whose execution could result in a resource conflict.

#### 753   5.1.7.10       [AVAI-SUM-SCHEDULE] Scheduling of updates

754   Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the ICT, the ICT  
755   shall support the scheduling of the application of updates that can impact the availability of these function with  
756   IMP.AVAI.TIME.Medium or higher.

### 757   5.1.8        Impact minimization

#### 758   5.1.9        Limit attack surface

##### 759   5.1.9.1       [LAS-INVAL] Validation of external data input

760   The ICT shall use input validation mechanisms for all external data input.

761       EXAMPLE:     If an application expects the input to be an email address, any input that does not conform to the  
762                       format of an e-mail address will be rejected.

763       NOTE 1: The specific pattern to accept external data input depends amongst others on the manner the external data  
764       input is intended to be processed. This means that an acceptance pattern for broad purposes (such as  
765       administration via a "Secure Shell") is typically less specific than an acceptance pattern for a specific  
766       purpose (such as a measurement value of a specific format to be stored).

767       NOTE 2: Typically the validation of different parts of the input will happen at different layers. Network layer of the  
768       operating system verify only information relevant to the network. An application verifies only input that  
769       is relevant to that application.

##### 770   5.1.9.2       [LAS-INSAN] Sanitization of external data input

771   The ICT shall use input sanitization mechanisms before using external data input as function input, where the validation  
772   of external data input cannot prevent potential incidents triggered by the external data input.

773       EXAMPLE:     If external data input is amongst others intended to be stored via a database service, escape  
774                       characters and other database service specific commands are removed from the external data input,  
775                       before it is processed by the database service.

##### 776   5.1.9.3       [LAS-PHY-INF] Only necessary physical interfaces

777   A hardware MP shall only provide physical interfaces, that are necessary for the ICT's intended purpose.

##### 778   5.1.9.4       [LAS-LOGIC-INF] Only necessary logical interfaces active by default

779   The ICT shall by default only use logical interfaces, that are necessary for its intended purpose.

##### 780   5.1.9.5       [LAS-APP] Only necessary apps by default

781   The ICT shall by default only use application softwares, that are necessary for its intended purpose.

### 5.1.9.6 [LAS-SBOOT] Secure boot

Where at least one function, whose use can cause harm with IMP.FH.High is provided by the ICT and the ICT includes a hardware MP, the hardware MP shall use a bootloader function that only executes core software at startup, whose integrity and authenticity is verified.

NOTE: The requirement corresponds to the verified boot capability in ETSI EN 304 623 [i.5]

## 5.1.10 Logging and monitoring mechanisms

### 5.1.10.1 [LOG-LOW] Events to log for low risk ICT

Where the ICT has a function, whose use can cause harm of impact class low as its highest function impact class, the ICT shall support logging mechanisms to create audit events for every:

- change of configuration affecting core software;
- starts, shutdowns or other changes of operational states of core software;
- errors of the core software.

### 5.1.10.2 [LOG-MEDIUM] Events to log for medium risk ICT

Where the ICT has a function, whose use can cause harm of impact class medium as its highest function impact class, the ICT shall use logging mechanisms to create audit events for every:

- unsuccessful authentication attempt;
- change of configuration affecting core software;
- starts, shutdowns or other changes of operational states of core software;
- errors of the core software;
- unsuccessful attempt of an identity to gain additional privileges;
- unsuccessful attempt of an identity to access a data asset or function asset.

### 5.1.10.3 [LOG-HIGH] Events to log for high risk ICT

Where the ICT has a function, whose use can cause harm of impact class high as its highest function impact class, the ICT shall use logging mechanisms to create audit events for every:

- every authentication attempt;
- change of configuration affecting core software;
- starts, shutdowns or other changes of operational states of core software;
- change of configuration affecting application software whom realize function, whose use can cause harm of impact class high;
- starts, shutdowns or other changes of operational states of application software whom realize function, whose use can cause harm of impact class high;
- errors of the core software;
- errors of the application software whom realize function, whose use can cause harm of impact class high;
- every attempt of an identity to gain additional privileges;
- every attempt of an identity to access a data asset or function asset.

#### 817 5.1.10.4 [LOG-TIME] Timestamps for logs

818 Where the ICT does not has a function, whose use can cause harm of impact class high, the ICT shall use at least a time  
819 service or function to include a timestamp in every audit event, created by the ICT.

#### 820 5.1.10.5 [LOG-TIME-HIGH] Real-Timestamps for logs

821 Where the ICT has a function, whose use can cause harm of impact class high as its highest function impact class, the  
822 ICT shall use a real-time service or clock to include a real-time timestamp in every audit event, created by the ICT.

#### 823 5.1.10.6 [LOG-STORAGE] Persistently store logfiles

824 Where the ICT has a function, whose use can cause harm of impact class medium or higher as its highest function  
825 impact class, the ICT shall use integrity protecting secure storage mechanisms to store every audit event created by the  
826 ICT persistently.

#### 827 5.1.10.7 [LOG-BACKUP] Backup of logfiles

828 Where the ICT has a function, whose use can cause harm of impact class high as its highest function impact class, the  
829 ICT shall automatically back up its audit events to another device or another part of the ICT that is in another physical  
830 location.

#### 831 5.1.11 Deletion mechanisms

#### 832 5.1.12 Other product's technical requirements specifications

##### 833 5.1.12.1 [USERNOT-NOSECFUC] User notifications on not available security 834 functions

835 The ICT shall notify a guardian when security functions that are supposed to be used or supported by the ICT are not  
836 available.

### 837 5.2 Requirements specifications for vulnerability handling 838 activities related to the product

839 The requirements specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1] shall be fulfilled for the ICT.

---

## 840 6 Assessing for compliance with requirements

### 841 6.1 Assessing for compliance with product's technical 842 requirements specifications

#### 843 6.1.1 General

844 In order to assess the compliance with the requirements listed in clause [5.1](#) of the present document, the assessment  
845 procedures described in clause [6.1](#) are to be followed. When performing assessments, the distribution of security  
846 functions (see clause [4.5](#)) are to be considered, including whether the product provides security functions itself,  
847 demands them from other products with digital elements within its context, or supplies them to other products with  
848 digital elements.

If there are already existing evidences (e.g. provided by manufacturers of components that are integrated in the ICT) that:

- are covering the same assessment activities as described in clause [6.1](#); and
- are valid for the moment of the assessment to be performed under clause [6.1](#).

Those existing evidences can be used for the "assignment of verdict" and as "supporting evidence".

## 6.1.2 Known exploitable vulnerabilities

### 6.1.2.1 Assessment criteria for [NKEV-MKAV]

## 6.1.3 Default configuration

### 6.1.3.1 Assessment criteria for [SDC-FRM]

#### **Assessment objective:**

The assessment functionally determines whether all user data, installed applications, and configurations deviating from the default state are erased after using the factory reset mechanism.

#### **Assessment preparation:**

- Documentation on how the factory reset mechanism can be accessed.
- The ICT shall be set up and some configuration changes shall be created and persistently stored.
- Where the ICT supports the storage of user data, some user data shall be created and persistently stored on the ICT.
- Where the ICT supports the installation of applications, some common application for the ICT shall be installed.

NOTE: user data also encompasses cryptographic keys, e.g. WIFI passwords, certificates.

#### **Assessment activities:**

- An authorized entity shall start the factory reset mechanism.
- The erasure of user data, applications and configurations shall be validated:
  - The restoration of the device settings to their default state shall be validated.
- Attempts to access any previous user accounts or data shall be made.

#### **Assignment of verdict:**

The verdict PASS shall be assigned when all user data, installed applications, and configurations deviating from the default state are erased

The verdict FAIL shall be assigned otherwise.

#### **Supporting Evidence:**

- Description of the performed test
- All test records of the performed test

## 6.1.4 Authentication and access control mechanisms

### 6.1.4.1 Assessment criteria for [ACM-FH]

#### Assessment objective:

The assessment covers:

- a conceptual assessment of ACM-FH;
- a functional completeness assessment on the ICT capabilities that are addressed by ACM-FH;
- a functional sufficiency assessment of each access control mechanism used by the ICT to fulfil ACM-FH,

based on the default configuration required by clause [5.1.2](#).

#### Assessment preparation:

The following documentation for the ICT shall be complete:

- a list of ICT's functions whose use can cause harm;
- for each function, whose use can cause harm:
  - its impact class impact class for function, whose use can cause harm;
  - the physical operational environment of the architectural component that performs the function;
  - for each of the function's trigger input possibilities:
    - the interface and communication type;
    - a list of corresponding access control mechanisms including their default authorization policy.

The following test setups shall be prepared:

- a test setup for identifying functions, their trigger input possibilities and corresponding access control mechanisms based on a sample ICT in default configuration;
- for each access control mechanism, a test setup that allows privilege escalation attacks from authenticated entities and unauthorized access attempts of unauthenticated entities.

#### Assessment activities:

- The ICT's conformity to ACM-FH shall be validated based on the documentation.
- The correctness and completeness of the documentation shall be verified by:
  - an inspection of the ICT for functions and related access control mechanisms that are accessible via physical human interfaces;
  - a scan of the ICT for functions and related access control mechanisms that are accessible via logical interfaces.
- For each access control mechanism, its correct implementation shall be verified based on attempts to violate the authorization policy by:
  - privilege escalation of authenticated entities based on the default authorization policy;
  - unauthorized usage of function, whose use can cause harm by unauthenticated entities based on the default authorization policy.

**Assignment of verdict:**

The verdict PASS shall be assigned if:

- the documentation indicates the ICT's conformity to ACM-FH; and
- the verification of the correctness and completeness of the documentation was successful; and
- the verification of the correct implementation of each access control mechanism was successful.

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- records of the validation of the documentation;
- descriptions of the performed tests and records of performed tests to verify the correctness and completeness of the documentation; and
- descriptions of the performed tests and records of performed tests to verify the correct implementation of each access control mechanism.

**6.1.4.2 Assessment criteria for [AUM-FH]****Assessment objective:**

The assessment covers:

- a conceptual assessment of AUM-FH;
- a functional completeness assessment on the ICT capabilities that are addressed by AUM-FH; and
- a functional sufficiency assessment of each authentication mechanism used by the ICT to fulfil AUM-FH, based on the default configuration required by clause [5.1.2](#).

**Assessment preparation:**

The following documentation for the ICT shall be complete:

- a list of ICT's functions whose use can cause harm;
- for each function, whose use can cause harm:
  - its impact class impact class for function, whose use can cause harm;
  - the physical operational environment of the architectural component that performs the function;
  - for each of the function's trigger input possibilities:
    - the interface and communication type;
    - a list of corresponding authentication mechanisms including:
      - the authentication mechanisms' strength;
      - the type of authentication factors.

The following test setups shall be prepared:

- a test setup for identifying functions, their trigger input possibilities and corresponding authentication mechanisms based on a sample ICT in default configuration;
- for each authentication mechanism, a test setup defined by the test cases provided in clause [E.3](#) according to the needs determined by its strength and the type of its authentication factors.



**Assessment activities:**

- The ICT's conformity to ACM-FH shall be validated based on the documentation.
- The correctness and completeness of the documentation shall be verified by:
  - an inspection of the ICT for functions and related authentication mechanisms that are accessible via physical human interfaces;
  - a scan of the ICT for functions and related authentication mechanisms that are accessible via logical interfaces.
- For each authentication mechanism, its correct implementation shall be verified based on the test cases provided in clause [E.3](#) according to the needs determined by its strength and the type of its authentication factors.

**Assignment of verdict:**

The verdict PASS shall be assigned if:

- the documentation indicates the ICT's conformity to ACM-FH; and
- the verification of the correctness and completeness of the documentation was successful; and
- the verification of the correct implementation of each authentication mechanism was successful.

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- records of the validation of the documentation;
- descriptions of the performed tests and records of performed tests to verify the correctness and completeness of the documentation;
- descriptions of the performed tests and records of performed tests to verify the correct implementation of each authentication mechanism.

**6.1.4.3 Assessment criteria for [AUTHZ-LP]****Assessment objective:**

The assessment covers:

- a conceptual assessment of AUTHZ-LP.

based on the default configuration required by clause [5.1.2](#).

**Assessment preparation:**

The following documentation for the ICT shall be complete:

- a description of the authorization policies in default configuration including:
  - a list of granted permissions for entities on function, whose use can cause harm; and
  - for each granted permission, a justification that it is necessary for the intended purpose.

**Assessment activities:**

- The ICT's conformity to {requirement\_authz:AUTHZ-LP} shall be validated based on the documentation.

**Assignment of verdict:**

The verdict PASS shall be assigned if:

- the documentation indicates the ICT's conformity to AUTHZ-LP.

987 The verdict FAIL shall be assigned otherwise.

988 **Supporting Evidence:**

- 989     • records of the validation of the documentation.

990 **6.1.4.4 Assessment criteria for [AUTHZ-R]**

991 **Assessment objective:**

992 The assessment covers:

- 993     • a functional sufficiency assessment to ensure the ICT supports revocation of any granted permissions.

994 **Assessment preparation:**

995 The following documentation for the ICT shall be complete:

- 996     • a list of mechanisms to grant permissions for entities on function, whose use can cause harm.

997 The following test setups shall be prepared:

- 998     • for each mechanism to grant permissions, a test setup for granting and revoking permissions for entities on  
999 function, whose use can cause harm.

1000 **Assessment activities:**

- 1001     • For each mechanism to grant permissions, the revocability of grantable permissions shall be verified by:
- 1002         - granting permissions to an entity;
- 1003         - revoking the permissions; and
- 1004         - attempting use permissions after revocation.

1005 **Assignment of verdict:**

1006 The verdict PASS shall be assigned if:

- 1007     • for each mechanism to grant permissions, access is denied after revocation.

1008 The verdict FAIL shall be assigned otherwise.

1009 **Supporting Evidence:**

- 1010     • descriptions of the performed tests and records of performed tests to verify the correct implementation of  
1011 AUTHZ-R.

1012 **6.1.5 Integrity protection**

1013 **6.1.6 Confidentiality protection**

1014 **6.1.7 Data minimization**

1015 **6.1.7.1 Assessment criteria for [DMIN-DJST]**

1016 **Assessment objective:**

1017 The assessment covers:

- 1018     • a conceptual assessment of Documented justification of processed data;

- 1019 • a functional sufficiency assessment of each mechanism and/or configuration used by the ICT to fulfil  
1020 Documented justification of processed data; and
- 1021 • a functional completeness assessment on the ICT capabilities that are addressed by Documented justification  
1022 of processed data.

### 1023 **Assessment preparation:**

1024 The following documentation for the ICT shall be complete:

- 1025 • a list of all documented data sources and destinations to which processed data is transmitted or made  
1026 accessible (if applicable), processed by the ICT in its default configuration;
- 1027 • a list of all data assets processed by the ICT whose impact class for confidential ICT data is IMP.CONF.Low  
1028 or higher;
- 1029 • for each documented confidential data asset, the associated rationale for its necessity explaining why its  
1030 processing is necessary for the intended purpose of the ICT; and
- 1031 • a description of the mechanisms and/or configurations used to ensure data minimization (e.g. code modules for  
1032 data filtering, configuration settings that limit data intake, architectural diagrams showing data flows, or  
1033 policies that prevent unnecessary processing).

1034 NOTE: The documentation of sources and destinations may be combined where a data flow is bidirectional or  
1035 where source and destination are the same entity.

1036 The following shall be prepared:

- 1037 • a methodology capable of detecting and listing all data sources actually processed by an ICT in its default  
1038 configuration and, where applicable, the destinations (set up communication partners) to which data is  
1039 transmitted or made accessible (e.g. network traffic analysis, log inspection, dynamic analysis tools,  
1040 source-code review where available, interface enumeration, etc.); and
- 1041 • test setups to evaluate the data minimization mechanisms and/or configurations, including attempts to trigger  
1042 or configure the ICT to process additional data beyond the documented and justified items (e.g. via  
1043 configuration changes, input simulations, or interface probing), based on the described mechanisms and/or  
1044 configurations.

### 1045 **Assessment activities:**

- 1046 • the correctness and completeness of the documentation shall be verified by:
  - 1047 - using the prepared methodology, identify and list all data sources (and destinations, if applicable) that are  
1048 actually processed by the sample ICT in its default configuration;
  - 1049 - comparing the identified data sources/destinations with the documented list;
  - 1050 - for every confidential data item that is documented, verifying that a clear and plausible rationale is  
1051 provided showing that its processing is necessary for the intended purpose and reasonably foreseeable  
1052 use;
  - 1053 - verifying that no confidential data item is processed for which no documentation or no sufficient  
1054 rationale exists;
  - 1055 - reviewing the described data minimization mechanisms and/or configurations for conceptual sufficiency  
1056 (e.g. ensure they align with best practices for limiting data to necessities, such as least-privilege data  
1057 access or runtime checks); and
  - 1058 - performing functional tests on the mechanisms and/or configurations using the prepared test setups to  
1059 confirm they prevent or restrict processing of undocumented or unjustified data (e.g. attempt to enable  
1060 optional data collection features and verify if they are disabled by default or require explicit justification;  
1061 simulate inputs that could lead to extra data processing and check if they are filtered or ignored).

**Assignment of verdict:**

The verdict PASS shall be assigned if:

- all actually processed data sources/destinations are documented;
- every documented data item has a sufficient rationale demonstrating necessity for the intended purpose and reasonably foreseeable use;
- no undocumented or unjustified confidential data processing is observed;
- the described mechanisms and/or configurations are conceptually sufficient to enforce data minimization; and
- functional tests confirm that the mechanisms and/or configurations only process necessary data.

Otherwise, the verdict FAIL shall be assigned.

**Supporting Evidence:**

- descriptions of the performed tests and documentation of associated test records to verify the correctness and completeness of the documentation; and
- descriptions of the performed tests and documentation of associated test records that verify the correct implementation of each data minimization mechanism and/or configuration.

## 6.1.8 Availability protection

### 6.1.8.1 Assessment criteria for [AVAI-TIME-RECO-POW]

**Assessment objective:**

The assessment covers:

- a functional sufficiency assessment of the recovery function interaction with each power supply used by the ICTs MP to fulfil AVAI-TIME-RECO-POW,

based on the default configuration required by clause [5.1.2](#).

**Assessment preparation:**

The following documentation for the ICT shall be complete:

- a list of all power supplies used by the ICTs MP:
  - for each power supply: a description whether a power supply can power the MP alone;
- a list of all functionalities of the ICT that need communication involving the MP:
  - for each of these functionalities:
    - a list of interfaces of the ICT, where the connection status of the necessary communication channels can be read; or
    - parameters of the necessary communication channel of the MP in order to externally observe if the connection is active;
  - a list of interfaces of the ICT, where the operational status of the MP can be read:
    - description how the operational status can be implied from the interface readings.

The following test setups shall be prepared:

- the ICT is set up in default configuration;

- 1097 • a test setup to:
- 1098 - safely disconnect or disable and reconnect or enable the power supplies of the ICTs MP;
- 1099 - enable access to at least one interfaces of the ICT, where the operational status of the ICT can be read;
- 1100 - enable access to at least one interfaces of the ICT, where the connection status the necessary
- 1101 communication channels status of the MP can be read;
- 1102 - if the connection status for all necessary communication channels of the MP cannot be read from the
- 1103 ICT:
- 1104 ▪ monitor whether all necessary communication channels of the MP are active.

#### 1105 **Assessment activities:**

1106 The following activities shall be performed:

- 1107 • for every possible order in which the MP's power supplies can be disconnected or disabled:
- 1108 - disconnect or disable the all power supplies of the MP;
- 1109 - wait at least 30 s;
- 1110 - reconnect or enable the power supplies;
- 1111 - monitor the operational status of the ICT;
- 1112 - monitor the connection status for all necessary communication channels of the MP;
- 1113 - record the order in which the power supplies are disconnect or disable and reconnect or enable;
- 1114 - record the time relative to the reconnection or enabling of the last power supply, after which the ICT
- 1115 indicates, that it is operational and all necessary communication channels are established; or
- 1116 - record the time relative to the reconnection or enabling of the last power supply, after which every
- 1117 necessary communication channels of the MP was active at least once, and there is no indication that the
- 1118 ICT has not resumed operation.

#### 1119 **Assignment of verdict:**

1120 The verdict PASS shall be assigned if:

- 1121 • the ICT signals resume of operations and establishment of all necessary communication channels within one
- 1122 hour after the reconnection or enabling of the last power supply; or
- 1123 • all necessary communication channels of the MP were active at least once, and there is no indication that the
- 1124 ICT has not resumed operation within one hour.

1125 The verdict FAIL shall be assigned otherwise.

#### 1126 **Supporting Evidence:**

- 1127 • descriptions of the performed tests and records of performed tests.

### 1128 **6.1.8.2 Assessment criteria for [AVAI-TIME-NETW]**

#### 1129 **Assessment objective:**

1130 The assessment covers:

- 1131 • a conceptual assessment of AVAI-TIME-NETW;
- 1132 • a functional completeness assessment on the ICT capabilities that are addressed by AVAI-TIME-NETW;

- 1133       • a functional sufficiency assessment of each time sensitive function without the need of network connectivity to  
1134       operate used by the ICT to fulfil AVAI-TIME-NETW,

1135 based on the default configuration required by clause [5.1.2](#).

1136 **Assessment preparation:**

1137 The following documentation for the ICT shall be complete:

- 1138       • a list of all time sensitive function of the ICT:
- 1139           - for each time sensitive function;
- 1140           - description of the functionalities realized or supported by this function;
- 1141           - list of interfaces necessary for the operation of this function:
- 1142               ▪ for each interface;
- 1143               ▪ communication types of the interface;
- 1144       • a list of interfaces of the ICT, where the status of the MPs time sensitive function can be read:
- 1145           - description how the status can be implied from the interface readings.

1146 The following test setups shall be prepared:

- 1147       • the ICT is set up in default configuration;
- 1148       • a test setup to:
- 1149           - disconnect or disable the public communication of the ICTs MP;
- 1150           - disconnect or disable the adjacent communication of the ICTs MP;
- 1151           - enable access to at least one interfaces of the ICT, where the status of the ICTs time sensitive function  
1152           can be read.

1153 **Assessment activities:**

1154 The following activities shall be performed:

- 1155       • verify the correctness and completeness of the documentation;
- 1156       • repeat the following steps for communication types public communication, adjacent communication and both,  
1157       depending on the communication type needed by the functions to be tested:
- 1158           - disconnect or disable the corresponding communication type of the ICTs MP;
- 1159           - wait at least 30 s;
- 1160           - for each time sensitive function which does not need any interface with the corresponding  
1161           communication type for its operation:
- 1162               ▪ check whether the function is in operable status;
- 1163               ▪ record the status of the function and the disconnected or disabled communication type;
- 1164           - reconnect or enable the corresponding communication type.

1165 **Assignment of verdict:**

1166 The verdict PASS shall be assigned if:

- 1167       • no indication, that the documentation is incorrect or incomplete, are found;
- 1168       • all checked time sensitive functions are in operable state.

1169 The verdict FAIL shall be assigned otherwise.

1170 **Supporting Evidence:**

- 1171 • descriptions of the performed tests and records of performed tests.

1172 **6.1.9 Impact minimization**

1173 **6.1.10 Limit attack surface**

1174 **6.1.10.1 Assessment criteria for [LAS-SBOOT]**

1175 **Assessment objective:**

1176 The assessment covers:

- 1177 • a conceptual assessment of LAS-SBOOT;
- 1178 • a functional sufficiency assessment of the bootloader function used by the ICT to fulfil LAS-SBOOT.

1179 based on the default configuration required by clause [5.1.2](#).

1180 **Assessment preparation:**

1181 The following documentation for the ICT shall be complete:

- 1182 • SBOM of the ICT's hardware MP including information on which software's integrity and authenticity is  
1183 protected by the bootloader function;
- 1184 • documentation on how the bootloader function verifies the integrity and authenticity of the hardware MP's  
1185 software.

1186 The following test setup shall be prepared:

- 1187 • a test setup for installing integrity and authenticity tampered core software, including a software package  
1188 including the tampered core software; or
- 1189 • a test setup for tampering the integrity of installed core software.

1190 **Assessment activities:**

- 1191 • The ICT's conformity to LAS-SBOOT shall be validated based on the documentation.
- 1192 • The correct implementation of the bootloader function's integrity and authenticity verification of core software  
1193 shall be verified based on:
  - 1194 - tampering the integrity and authenticity of installed core software or installing integrity and authenticity  
1195 tampered core software; and
  - 1196 - restarting the ICT's hardware MP;

1197 **NOTE:** Typical results are:

- 1198 • the bootloader function refuses to execute the tampered core software (and thus does not execute application  
1199 software); and
- 1200 • either halts, resets, or boots into a secure fallback; and
- 1201 • an error indication is provided (e.g. via a log, an error code, an LED pattern, etc.).

1202 **Assignment of verdict:**

1203 The verdict PASS shall be assigned if:

- 1204 • the documentation indicates the ICT's conformity to LAS-SBOOT; and

1205       • the ICT's hardware MP does not execute the modified core software.

1206       Otherwise, the verdict FAIL shall be assigned.

1207       **Supporting Evidence:**

1208       • records of the validation of the documentation;

1209       • descriptions of the performed tests and documentation of associated test records that verify the correct  
1210       implementation of the bootloader function's integrity and authenticity verification.

1211       **6.1.11   Logging and monitoring mechanisms**

1212       **6.1.12   Deletion mechanisms**

1213       **6.1.13   Other product's technical requirements specifications**

1214       **6.2       Assessment criteria for vulnerability handling activities**  
1215       **related to the product**

1216       The assessment criteria specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1] shall be met for the  
1217       ICT based on the corresponding specified input and output.

1218



---

## Annex A (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847

**DRAFT ANNEX A - DO NOT CONSIDER THE CONTENT - See identified gaps in Annex F**

The present document has been prepared under the Commission's Standardisation request M/606 - C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table [A.1](#) confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**Table A.1: Relationship between the present document and the requirements of Regulation (EU) 2024/2847 [i.1]**

| Harmonised Standard ETSI EN 304 633 |                                                                                                                                             |                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |                            |           |
|-------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------|
| Requirement                         |                                                                                                                                             |                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Requirement Conditionality |           |
| No                                  | Description                                                                                                                                 | Requirements of Regulation | Clause(s) of the present document                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | U/C                        | Condition |
| 1                                   | The design, development, and production of products with digital elements ensures an appropriate level of cybersecurity based on the risks. | Annex I, Part I, (1)       | [ [ACM-FH] <a href="#">5.1.3.1</a><br>[AUM-FH] <a href="#">5.1.3.3</a><br>[AUTHZ-LP] <a href="#">5.1.3.4</a><br>[AUTHZ-R] <a href="#">5.1.3.5</a><br>[AUTHZ-PC] <a href="#">5.1.3.6</a><br>[AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a><br>[AVAI-TIME-NETW] <a href="#">5.1.7.2</a><br>[AVAI-TIME-RECO-NETW] <a href="#">5.1.7.3</a><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a><br>[AVAI-TIME-IMP-AMP] <a href="#">5.1.7.8</a><br>[AVAI-TIME-DOS-RATE] <a href="#">5.1.7.9</a><br>[AVAI-SUM-SCHEDULE] <a href="#">5.1.7.10</a><br>[CONF-SSM] <a href="#">5.1.5.1</a><br>[CONF-COM] <a href="#">5.1.5.2</a><br>[DMIN-DJST] <a href="#">5.1.6.1</a><br>[INT-SWPCK] <a href="#">5.1.4.1</a><br>[INT-COM] <a href="#">5.1.4.2</a><br>[LAS-INVAL] <a href="#">5.1.9.1</a><br>[LAS-INSAN] <a href="#">5.1.9.2</a><br>[LAS-PHY-INF] <a href="#">5.1.9.3</a><br>[LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[LAS-SBOOT] <a href="#">5.1.9.6</a><br>[LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[LOG-TIME] <a href="#">5.1.10.4</a><br>[LOG-TIME-HIGH] <a href="#">5.1.10.5</a><br>[LOG-STORAGE] <a href="#">5.1.10.6</a><br>[LOG-BACKUP] <a href="#">5.1.10.7</a><br>[NKEV-MKAV] <a href="#">5.1.1.1</a><br>[NKEV-SUM-SUPPORT] <a href="#">5.1.1.2</a><br>[NKEV-SUM-PROVIDE] <a href="#">5.1.1.3</a><br>[NKEV-SUM-AUTO] <a href="#">5.1.1.4</a><br>[NKEV-SUM-NOTIF] <a href="#">5.1.1.5</a><br>[PARCONT] <a href="#">5.1.3.2</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a><br>[SDC-SUM-AUTO] <a href="#">5.1.2.2</a><br>[SDC-SUM-NOTIF] <a href="#">5.1.2.3</a><br>[SDC-FRM] <a href="#">5.1.2.4</a><br>[SDC-PARCONT] <a href="#">5.1.2.5</a><br>[USERNOT-NOSECFC] <a href="#">5.1.12.1</a> ] | U                          |           |

| Harmonised Standard ETSI EN 304 633 |                                                                                                                                                                                                                                                                                                                                                                                                             |                            |                                                                                                                                                                                                                                                                                                                                                        |                            |           |
|-------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------|
| Requirement                         |                                                                                                                                                                                                                                                                                                                                                                                                             |                            |                                                                                                                                                                                                                                                                                                                                                        | Requirement Conditionality |           |
| No                                  | Description                                                                                                                                                                                                                                                                                                                                                                                                 | Requirements of Regulation | Clause(s) of the present document                                                                                                                                                                                                                                                                                                                      | U/C                        | Condition |
| 2                                   | Products with digital elements are made available on the market without known exploitable vulnerabilities.                                                                                                                                                                                                                                                                                                  | Annex I, Part I, (2)(a)    | [ [NKEV-MKAV] <a href="#">5.1.1.1</a> ]                                                                                                                                                                                                                                                                                                                | U                          |           |
| 3                                   | Products with digital elements are made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state.                                                                                                    | Annex I, Part I, (2)(b)    | [ [LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a><br>[SDC-SUM-AUTO] <a href="#">5.1.2.2</a><br>[SDC-SUM-NOTIF] <a href="#">5.1.2.3</a><br>[SDC-FRM] <a href="#">5.1.2.4</a><br>[SDC-PARCONT] <a href="#">5.1.2.5</a> ]                                                            | U                          |           |
| 4                                   | Products with digital elements ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them. | Annex I, Part I, (2)(c)    | [ [NKEV-SUM-SUPPORT] <a href="#">5.1.1.2</a><br>[NKEV-SUM-PROVIDE] <a href="#">5.1.1.3</a><br>[NKEV-SUM-AUTO] <a href="#">5.1.1.4</a><br>[NKEV-SUM-NOTIF] <a href="#">5.1.1.5</a><br>[SDC-SUM-AUTO] <a href="#">5.1.2.2</a><br>[SDC-SUM-NOTIF] <a href="#">5.1.2.3</a> ]                                                                               | U                          |           |
| 5                                   | Products with digital elements ensure protection from Unauthorized access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible Unauthorized access.                                                                                                                                                                | Annex I, Part I, (2)(d)    | [ [ACM-FH] <a href="#">5.1.3.1</a><br>[AUM-FH] <a href="#">5.1.3.3</a><br>[AUTHZ-LP] <a href="#">5.1.3.4</a><br>[AUTHZ-R] <a href="#">5.1.3.5</a><br>[AUTHZ-PC] <a href="#">5.1.3.6</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[PARCONT] <a href="#">5.1.3.2</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a> ] | U                          |           |
| 6                                   | Products with digital elements protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means.                                                                                                                                             | Annex I, Part I, (2)(e)    | [ [CONF-SSM] <a href="#">5.1.5.1</a><br>[CONF-COM] <a href="#">5.1.5.2</a> ]                                                                                                                                                                                                                                                                           | U                          |           |
| 7                                   | Products with digital elements protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorized by the user, and report on corruptions.                                                                                                                                            | Annex I, Part I, (2)(f)    | [ [INT-SWPCK] <a href="#">5.1.4.1</a><br>[INT-COM] <a href="#">5.1.4.2</a><br>[LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a> ]                                                                                                                                                     | U                          |           |

| Harmonised Standard ETSI EN 304 633 |                                                                                                                                                                                                                                                              |                            |                                                                                                                                                                                                                                                                                                                                                                                               |                            |           |
|-------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------|
| Requirement                         |                                                                                                                                                                                                                                                              |                            |                                                                                                                                                                                                                                                                                                                                                                                               | Requirement Conditionality |           |
| No                                  | Description                                                                                                                                                                                                                                                  | Requirements of Regulation | Clause(s) of the present document                                                                                                                                                                                                                                                                                                                                                             | U/C                        | Condition |
| 8                                   | Products with digital elements process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimization).                              | Annex I, Part I, (2)(g)    | [ [DMIN-DJST] <a href="#">5.1.6.1</a> ]                                                                                                                                                                                                                                                                                                                                                       | U                          |           |
| 9                                   | Products with digital elements protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks.                                                    | Annex I, Part I, (2)(h)    | [ [AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a><br>[AVAI-TIME-NETW] <a href="#">5.1.7.2</a><br>[AVAI-TIME-RECO-NETW] <a href="#">5.1.7.3</a><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a><br>[AVAI-TIME-DOS-RATE] <a href="#">5.1.7.9</a> ] | U                          |           |
| 10                                  | Products with digital elements minimize the negative impact by the products themselves or connected products on the availability of services provided by other products or networks.                                                                         | Annex I, Part I, (2)(i)    | [ [AVAI-TIME-IMP-AMP] <a href="#">5.1.7.8</a> ]                                                                                                                                                                                                                                                                                                                                               | U                          |           |
| 11                                  | Products with digital elements are designed, developed and produced to limit attack surfaces, including external interfaces.                                                                                                                                 | Annex I, Part I, (2)(j)    | [ [LAS-INVAL] <a href="#">5.1.9.1</a><br>[LAS-INSAN] <a href="#">5.1.9.2</a><br>[LAS-PHY-INF] <a href="#">5.1.9.3</a><br>[LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[LAS-SBOOT] <a href="#">5.1.9.6</a> ]                                                                                                                                                | U                          |           |
| 12                                  | Products with digital elements are designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques.                                                                                 | Annex I, Part I, (2)(k)    | [ [AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a> ]                                                                                                                                                                                                                                              | U                          |           |
| 13                                  | Products with digital elements provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user.                  | Annex I, Part I, (2)(l)    | [ [LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[LOG-TIME] <a href="#">5.1.10.4</a><br>[LOG-TIME-HIGH] <a href="#">5.1.10.5</a><br>[LOG-STORAGE] <a href="#">5.1.10.6</a><br>[LOG-BACKUP] <a href="#">5.1.10.7</a><br>[NKEV-SUM-NOTIF] <a href="#">5.1.1.5</a><br>[USERNOT-NOSECFUC] <a href="#">5.1.12.1</a> ]       | U                          |           |
| 14                                  | Products with digital elements provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner. | Annex I, Part I, (2)(m)    | [ [SDC-FRM] <a href="#">5.1.2.4</a> ]                                                                                                                                                                                                                                                                                                                                                         | U                          |           |

| Harmonised Standard ETSI EN 304 633 |                                     |                            |                                   |                            |           |
|-------------------------------------|-------------------------------------|----------------------------|-----------------------------------|----------------------------|-----------|
| Requirement                         |                                     |                            |                                   | Requirement Conditionality |           |
| No                                  | Description                         | Requirements of Regulation | Clause(s) of the present document | U/C                        | Condition |
| 15                                  | Vulnerability handling requirements | Annex I, Part II           | <a href="#">5.2</a>               | U                          |           |

1234

1235 **Requirement:**1236 **No** A unique identifier for one row of the table which may be used to identify a requirement.1237 **Description** A textual reference to the requirement.1238 **Essential requirements of Directive**

1239 Identification of article(s) defining the requirement in the Directive.

1240 **Clause(s) of the present document**1241 Identification of clause(s) defining the requirement in the present document unless another  
1242 document is referenced explicitly.1243 **Requirement Conditionality:**1244 **U/C** Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the  
1245 manufacturer's claimed functionality of the equipment (C).1246 **Condition** Explains the conditions when the requirement is or is not applicable for a requirement which is  
1247 classified "conditional".1248 Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list  
1249 published in the Official Journal of the European Union. Users of the present document should consult frequently the  
1250 latest list published in the Official Journal of the European Union.

1251 Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

1252

## Annex B (informative): Guidance for the application of the present document

The following approach can be used (e.g. by manufacturers)

- to develop products that are compliant the present document; or
- to analyse the compliance of a product to the present document.

The approach is constructed such that it uses parts of an assessment of cybersecurity risks and can be integrated into the management of cybersecurity risks.

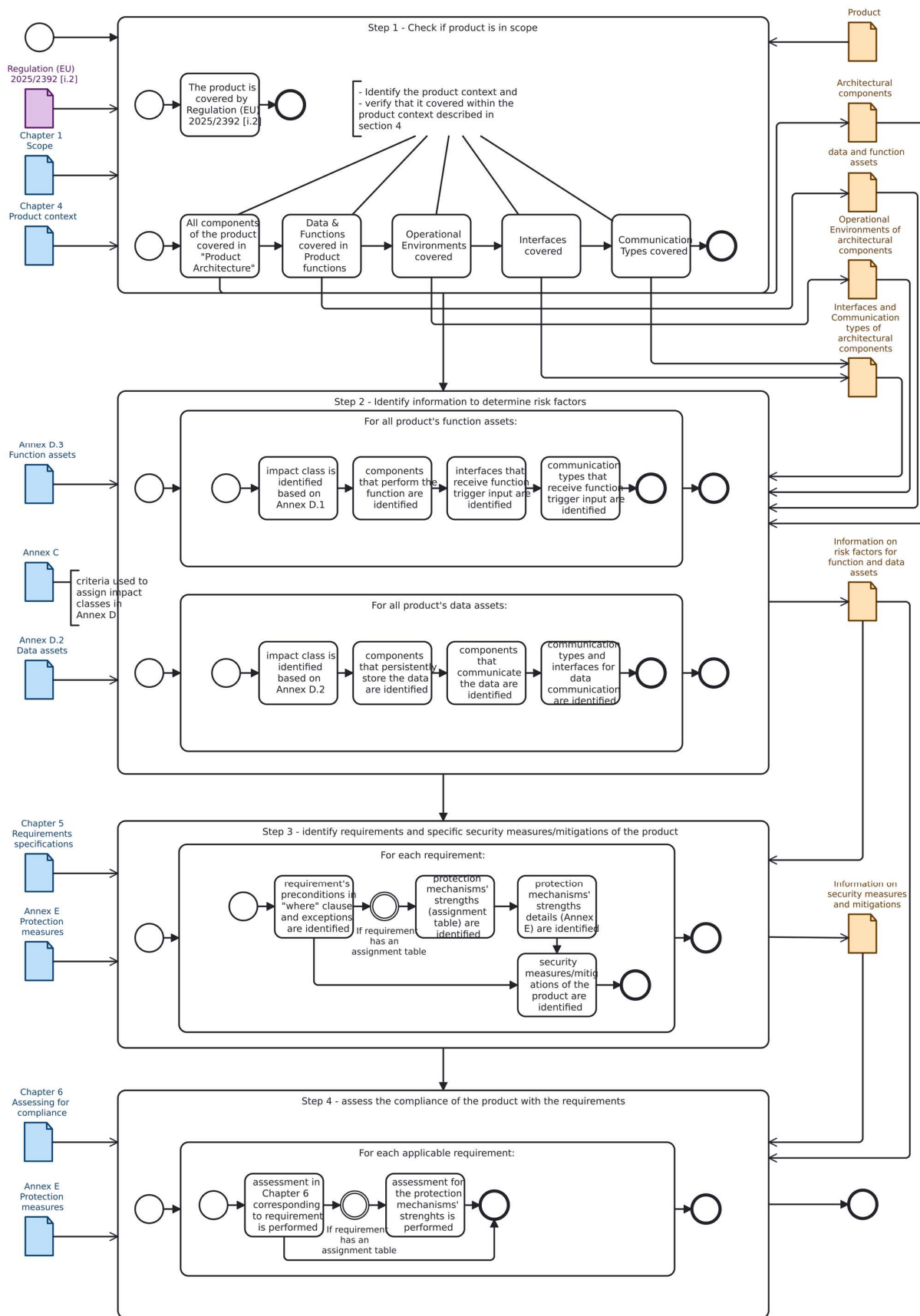
- Step 1 - check if the product is in scope of the present document provided in clause [1](#) by:
  - verifying that the product is a ICT as specified within the "technical description" of the "category of product" number "18." by Regulation (EU) 2025/2392 [i.2]; and
  - identifying the product context by:
    - identifying the product's architectural components; and
    - identifying all data processed by the product (data assets); and
    - identifying all functions provided by the product (function assets); and
    - identifying the architectural components' operational environments; and
    - identifying the architectural components' interfaces and communication types; and
  - verifying that the product is covered within the product context described in clause [4](#) by:
    - verifying that the architectural components of the product are covered within the product architecture described in clause [4.2](#); and
    - verifying that the data processed by the product and the functions provided by the product are covered within clause [4.1](#); and
    - verifying that the architectural components' operational environments are covered within clause [4.3](#); and
    - verifying that the architectural components' interfaces and communication types are covered within clause [4.4](#).

NOTE 1: The identification of the items mentioned above can be reused for assessing the compliance of the product with the requirements in clause [5](#).

NOTE 2: If a product is a ICT as specified by Regulation (EU) 2025/2392 [i.2] but is not covered within the product context described in clause [4](#), it is assumed that the product is not or not completely covered by the present document. In such cases informing ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR) via the [Committee Support Staff](#) might help to address those products in potential revisions of the present document.

- Step 2 - identify information to determine risk factors by:
  - identifying for each function provided by the product:
    - its impact classes according to clause [D.3](#); and
    - the architectural components that perform the function; and
    - the communication types and the interfaces that can receive corresponding function trigger input; and

- 1291 - identifying for each data processed by the product:
- 1292     ▪ its impact classes according to clause [D.2](#);
- 1293     ▪ the architectural components that persistently store the data; and
- 1294     ▪ the architectural components that can communicate the data; and
- 1295     ▪ the communication types and the interfaces over which the data is communicated.
- 1296 NOTE 3: If data processed by the product or functions provided by the product are not covered within clause [4.1](#),
- 1297 clause [C.1](#) can be used to identify impact classes for function and data assets that are outside the scope of
- 1298 the present document.
- 1299 • Step 3 - identify concrete requirements for and specific security measures/mitigations of the product that
- 1300 satisfy those requirements by:
- 1301 - for each requirement in clause [5](#):
- 1302     ▪ identifying the requirements applicability by evaluating the requirement's potential preconditions
- 1303     and exceptions based on the product's properties; and
- 1304     ▪ (for requirements that include assignment tables) identifying the required protection mechanisms'
- 1305     strengths (specified in annex [E](#)) by evaluating the requirement's assignment table based on the
- 1306     product's properties determining the attack surface and impact parameters; and
- 1307     ▪ identifying the specific security measures/mitigations that satisfy the requirement.
- 1308 NOTE 4: An assignment table can yield multiple mechanisms' strengths from different circumstances, which all
- 1309 have to be satisfied.
- 1310 EXAMPLE: Authentication requirements prior to changes of a ICTs configuration are different whether the
- 1311 changes can be made via a web GUI, accessible from adjacent or public networks, a GUI,
- 1312 accessible from the ICTs touchscreen, or a console, accessible by connecting to a serial port. All of
- 1313 this cases can be simultaneously present on the same ICT.
- 1314 • Step 4 - assess the compliance of the product with the requirements in clause [5](#) by:
- 1315 - for each requirement in clause [5](#), performing the corresponding assessment for compliance described in
- 1316 clause [6](#) (the functional sufficiency assessments for different protection measures strengths are specified
- 1317 in annex [E](#)) by:
- 1318     ▪ preparing the assessment for the product; and
- 1319     ▪ performing the assessment activities for the product; and
- 1320     ▪ assigning an assessment verdict for the product; and
- 1321     ▪ generating the supporting evidences for the assessment.
- 1322 Figure [B.1](#) provides a graphical representation of the guidance for the application of the present document.



**Figure B.1: Graphical representation on guidance for the application of the present document**



---

## Annex C (informative): Information on the methodology for the assessment of cybersecurity risks used to develop the present document

This informative annex is intended to provide information on the methodology for the assessment of cybersecurity risks used to develop the present document.

---

### C.1 Guidance for determining impact classes

#### C.1.1 General

The present document uses the following criteria to determine the impact classes of different specific ICT assets provided in annex D.

#### C.1.2 Confidential data

##### **confidentiality impact class low (IMP.CONF.Low):**

The disclosure may lead to:

- inconvenient consequences on the consumer(s); or
- additional or increased attack opportunities over a short time and limited to communication types not higher than local on the ICT.

##### **confidentiality impact class medium (IMP.CONF.Medium):**

The disclosure may lead to:

- serious impact on the consumer(s);
- additional or increased attack opportunities over a short time on the ICT or a limited number of other products; or
- additional or increased attack opportunities over a prolonged time limited to non-key-functionalities on the ICT.

##### **confidentiality impact class high (IMP.CONF.High):**

The disclosure may lead to:

- significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- additional or increased attack opportunities over a prolonged time on the ICT or a limited number of other products; or
- additional or increased attack opportunities over a short time on a significant number of other products.

#### C.1.3 Loss sensitive data

##### **loss sensitive availability impact class low (IMP.AVALLOSS.Low):**

The loss may lead to:

- inconvenient consequences on the consumer(s); or
- non-availability of non-key-functionalities on the ICT for a short time.

**loss sensitive availability impact class medium (IMP.AVALOSS.Medium):**

The loss may lead to:

- serious impact on the consumer(s); or
- non-availability of key-functionalities of the ICT over a short time; or
- non-availability of non-key-functionalities on the ICT for a prolonged time.

**loss sensitive availability impact class high (IMP.AVALOSS.High):**

The loss may lead to:

- significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- non-availability of key-functionalities of the ICT for a prolonged time; or
- permanent non-availability of non-key-functionalities of the ICT.

## C.1.4 Time sensitive data and time sensitive function

**time sensitive availability impact class low (IMP.AVAL.TIME.Low):**

The delay of availability may lead to:

- non-availability of non-key-functionalities on the ICT for a short time.

**time sensitive availability impact class medium (IMP.AVAL.TIME.Medium):**

The delay of availability may lead to:

- non-availability of key-functionalities on the ICT for a short time; or
- non-availability of non-key-functionalities on the ICT for a prolonged time.

**time sensitive availability impact class high (IMP.AVAL.TIME.High):**

The delay of availability may lead to:

- non-availability of key-functionalities of the ICT for a prolonged time; or
- permanent non-availability of non-key-functionalities of the ICT.

## C.1.5 Integrity relevant data and integrity relevant function

**integrity impact class low (IMP.INT.Low):**

The tampering may lead to:

- inconvenient consequences on the consumer(s);
- additional or increased attack opportunities for a short time and limited to communication types not higher than local on the ICT; or
- non-availability of non-key-functionalities on the ICT for a short time.

**integrity impact class medium (IMP.INT.Medium):**

The tampering may lead to:

- serious impact on the consumer(s);
- additional or increased attack opportunities over a short time on the ICT or a limited number of other products;

- 1391 • additional or increased attack opportunities over a prolonged time limited to non-key-functionalities on the  
1392 ICT; or
- 1393 • non-availability of key-functionalities on the ICT for a short time; or
- 1394 • non-availability of non-key-functionalities on the ICT for a prolonged time.

1395 **integrity impact class high (IMP.INT.High):**

1396 The tampering may lead to:

- 1397 • significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- 1398 • additional or increased attack opportunities for a prolonged time on the ICT or a limited number of other  
1399 products;
- 1400 • additional or increased attack opportunities for a short time on a significant number of other products;
- 1401 • non-availability of key-functionalities of the ICT for a prolonged time; or
- 1402 • permanent non-availability of non-key-functionalities of the ICT.

1403

---

## Annex D (normative): Relationship between specific data and functions assets covered by the present document to impact classes for generic asset categories

### D.1 Identifier

The following identifier for impact classes apply:

**IMP:** impact class

**IMP.Low:** impact class low

**IMP.Medium:** impact class medium

**IMP.High:** impact class high

**IMP.CONF:** confidentiality impact class

**IMP.CONF.Low:** confidentiality impact class low

**IMP.CONF.Medium:** confidentiality impact class medium

**IMP.CONF.High:** confidentiality impact class high

**IMP.INT:** integrity impact class

**IMP.INT.Low:** integrity impact class low

**IMP.INT.Medium:** integrity impact class medium

**IMP.INT.High:** integrity impact class high

**IMP.AVAL.TIME:** time sensitive availability impact class

**IMP.AVAL.TIME.Low:** time sensitive availability impact class low

**IMP.AVAL.TIME.Medium:** time sensitive availability impact class medium

**IMP.AVAL.TIME.High:** time sensitive availability impact class high

**IMP.AVAL.LOSS:** loss sensitive availability impact class

**IMP.AVAL.LOSS.Low:** loss sensitive availability impact class low

**IMP.AVAL.LOSS.Medium:** loss sensitive availability impact class medium

**IMP.AVAL.LOSS.High:** loss sensitive availability impact class high

**IMP.FH:** impact class for function, whose use can cause harm

**IMP.FH.Low:** function, whose use can cause harm impact class low

**IMP.FH.Medium:** function, whose use can cause harm impact class medium

**IMP.FH.High:** function, whose use can cause harm impact class high

**IMP.FH.SP:** function, whose use can impact the safety or privacy of human entities impact class

**IMP.FH.SP.Low:** function, whose use can impact the safety or privacy of human entities impact class low

**IMP.FH.SP.Medium:** function, whose use can impact the safety or privacy of human entities impact class medium

- 1437 **IMP.FH.SP.High:** function, whose use can impact the safety or privacy of human entities impact class high
- 1438 **IMP.FH.DSN:** function, whose use can impact the availability of other devices, services or networks impact class
- 1439 **IMP.FH.DSN.Low:** function, whose use can impact the availability of other devices, services or networks impact class
- 1440 low
- 1441 **IMP.FH.DSN.Medium:** function, whose use can impact the availability of other devices, services or networks impact
- 1442 class medium
- 1443 **IMP.FH.DSN.High:** function, whose use can impact the availability of other devices, services or networks impact class
- 1444 high
- 1445 **IMP.FH.CCON:** function, which can communicate confidential data impact class
- 1446 **IMP.FH.CCON.Low:** function, which can communicate confidential data impact class low
- 1447 **IMP.FH.CCON.Medium:** function, which can communicate confidential data impact class medium
- 1448 **IMP.FH.CCON.High:** function, which can communicate confidential data impact class high
- 1449 **IMP.FH.MINT:** function, which can modify integrity relevant data impact class
- 1450 **IMP.FH.MINT.Low:** function, which can modify integrity relevant data impact class low
- 1451 **IMP.FH.MINT.Medium:** function, which can modify integrity relevant data impact class medium
- 1452 **IMP.FH.MINT.High:** function, which can modify integrity relevant data impact class high

## D.2 Data assets

**Table D.1: Mapping of specific data assets to impact classes for generic data asset categories**

| Specific data asset                    | Impact class for data asset categories                                    |                                                                            |                                                               |                                                               |
|----------------------------------------|---------------------------------------------------------------------------|----------------------------------------------------------------------------|---------------------------------------------------------------|---------------------------------------------------------------|
|                                        | Impact class for confidential ICT data                                    | Impact class for integrity relevant ICT data                               | Impact class for time critical availability relevant ICT data | Impact class for loss critical availability relevant ICT data |
| <b>MP position data</b>                | IMP.CONF.Medium                                                           | IMP.INT.Medium                                                             | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| <b>Emergency location sharing data</b> | IMP.CONF.Low                                                              | IMP.INT.Medium                                                             | IMP.AVAI.TIME.High                                            | IMP.AVAI.LOSS.Low                                             |
| <b>Geofence location data</b>          | IMP.CONF.Low                                                              | IMP.INT.Medium                                                             | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| <b>Social interactive data</b>         | IMP.CONF.Medium                                                           | IMP.INT.Medium                                                             | IMP.AVAI.TIME.Low                                             | IMP.AVAI.LOSS.Medium                                          |
| <b>Audio input data</b>                | IMP.CONF.Medium                                                           | IMP.INT.Medium                                                             | IMP.AVAI.TIME.Low                                             | no                                                            |
| <b>Video input data</b>                | IMP.CONF.Medium                                                           | IMP.INT.Medium                                                             | IMP.AVAI.TIME.Low                                             | no                                                            |
| <b>Network status data</b>             | IMP.CONF.Medium                                                           | IMP.INT.Medium                                                             | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| <b>Authorization policy data</b>       | IMP.CONF.Medium                                                           | IMP.INT.High                                                               | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| <b>ICT state data</b>                  | IMP.CONF.Medium                                                           | IMP.INT.Medium                                                             | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| <b>Logging data</b>                    | IMP.CONF =<br>IMP.CONF of confidential data contained in the logging data | IMP.INT = Highest<br>/IncludeIDE{ImpactClass:FunctionWhoseUseCanCauseHarm} | IMP.AVAI.TIME.Low                                             | IMP.AVAI.LOSS.Medium                                          |
| <b>Software package</b>                | IMP.CONF =<br>IMP.CONF of confidential data contained in the package      | IMP.INT = Highest<br>IMP.INT of ICT's integrity relevant function          | no                                                            | no                                                            |

## D.3 Function assets

**Table D.2: Mapping of specific function assets to impact classes for generic function asset categories**

| Specific function asset                     | Impact class for function asset categories                 |                                                    |                                                              |
|---------------------------------------------|------------------------------------------------------------|----------------------------------------------------|--------------------------------------------------------------|
|                                             | Impact class for integrity relevant function               | Impact class for time sensitive function           | Impact class for function, whose use can cause harm          |
| Positioning function                        | IMP.INT.Medium                                             | IMP.AVAI.TIME.Medium                               | IMP.FH.Medium                                                |
| Location sharing function                   | IMP.INT.Medium                                             | IMP.AVAI.TIME.Medium                               | IMP.FH.Medium                                                |
| Emergency location function                 | IMP.INT.Medium                                             | IMP.AVAI.TIME.High                                 | IMP.FH.Medium                                                |
| Geo fencing notification function           | IMP.INT.Medium                                             | IMP.AVAI.TIME.Medium                               | IMP.FH.Medium                                                |
| Parental control function                   | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| Audio input function                        | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| Video input function                        | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| Audio output function                       | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| Video output function                       | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| ICT function which can communicate ICT data | IMP.INT = Maximum (IMP.CONF, IMP.INT) of communicated data | IMP.AVAI.TIME = IMP.AVAI.TIME of communicated data | IMP.FH = Maximum (IMP.FH.Low, IMP.CONF of communicated data) |
| Connection function                         | IMP.INT.Low                                                | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| ICT function which can modify ICT data      | IMP.INT = IMP.INT of modified data                         | no                                                 | IMP.FH = IMP.INT of modified data                            |

### D.3.1 Functions whose use can cause harm

The contents of the column *impact class for function, whose use can cause harm* of table [D.2](#) are split into details in table [D.3](#).

**Table D.3: Mapping of specific function assets to impact classes for different aspects of function, whose use can cause harm**

| Specific function asset                     | Impact class for function asset categories                                              |                                                                                                         |                                                                    |                                                                     |                                                              |
|---------------------------------------------|-----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|---------------------------------------------------------------------|--------------------------------------------------------------|
|                                             | Impact class for function, whose use can impact the safety or privacy of human entities | Impact class for function, whose use can impact the availability of other devices, services or networks | Impact class for function, which can communicate confidential data | Impact class for function, which can modify integrity relevant data | Impact class for function, whose use can cause harm          |
| Positioning function                        | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| Location sharing function                   | IMP.FH.SP.Medium                                                                        | IMP.FH.DSN.Low                                                                                          | IMP.FH.CCON.Medium                                                 | no                                                                  | IMP.FH.Medium                                                |
| Emergency location function                 | IMP.FH.SP.Low                                                                           | IMP.FH.DSN.Low                                                                                          | IMP.FH.CCON.Low                                                    | no                                                                  | IMP.FH.Medium                                                |
| Geo fencing notification function           | IMP.FH.SP.Medium                                                                        | IMP.FH.DSN.Low                                                                                          | IMP.FH.CCON.Low                                                    | no                                                                  | IMP.FH.Medium                                                |
| Parental control function                   | no                                                                                      | no                                                                                                      | IMP.FH.CCON.Low                                                    | IMP.FH.MINT.Medium                                                  | IMP.FH.Medium                                                |
| Audio input function                        | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| Video input function                        | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| Audio output function                       | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| Video output function                       | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| ICT function which can communicate ICT data | no                                                                                      | IMP.FH.DSN.Low                                                                                          | IMP.FH.CCON = IMP.CONF of communicated data                        | no                                                                  | IMP.FH = Maximum (IMP.FH.Low, IMP.CONF of communicated data) |
| Connection function                         | no                                                                                      | IMP.FH.DSN.Medium                                                                                       | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| ICT function which can modify ICT data      | no                                                                                      | no                                                                                                      | no                                                                 | IMP.FH.MINT = IMP.INT of modified data                              | IMP.FH = IMP.INT of modified data                            |

---

## Annex E (normative): Protection measures

### E.1 Identifier

The following identifier apply here and in the assignment tables in clause 5:

**N/A:** not applicable

**AUTH.Basic:** authentication strength level basic

**AUTH.Normal:** authentication strength level normal

**AUTH.Enhanced:** authentication strength level enhanced

**AUTH.Strong:** authentication strength level strong

**CONF.COM.Basic:** communication of confidential data protection strength level basic

**CONF.COM.Normal:** communication of confidential data protection strength level normal

**CONF.COM.Enhanced:** communication of confidential data protection strength level enhanced

**CONF.COM.Strong:** communication of confidential data protection strength level strong

**INT.COM.Basic:** communication of integrity relevant data protection strength level basic

**INT.COM.Normal:** communication of integrity relevant data protection strength level normal

**INT.COM.Enhanced:** communication of integrity relevant data protection strength level enhanced

**INT.COM.Strong:** communication of integrity relevant data protection strength level strong

**CONF.SSM.Basic:** confidential persistent storage strength level basic

**CONF.SSM.Normal:** confidential persistent storage strength level normal

**CONF.SSM.Enhanced:** confidential persistent storage strength level enhanced

**CONF.SSM.Strong:** confidential persistent storage strength level strong

**SAN.Normal:** input sanitization of input strength level normal

**SAN.Strong:** input sanitization of input strength level strong

**AUT.VER.Enhanced:** authenticity verification strength level enhanced

**AUT.VER.Strong:** authenticity verification strength level strong

**INT.SW.VER.Basic:** software package integrity verification strength level basic

**INT.SW.VER.Normal:** software package integrity verification strength level normal

**INT.SW.VER.Enhanced:** software package integrity verification strength level enhanced

**INT.SW.VER.Strong:** software package integrity verification strength level strong

**INT.VER.Basic:** integrity verification strength level basic

**INT.VER.Normal:** integrity verification strength level normal

**INT.VER.Enhanced:** integrity verification strength level enhanced

**INT.VER.Strong:** integrity verification strength level strong



---

## E.2 access control mechanism's strength

---

## E.3 authentication mechanism strength

---

### E.3.1 AUM-FH Authentication for functions whose use can cause harm

#### E.3.1.1 General

The present document specifies the strength of authentication mechanisms by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

#### E.3.1.2 Authentication strength level basic

The authentication strength level basic shall protect against the following attack types:

**limited presentation attack:** Opportunistic presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using authentication factors of another entity.

**limited brute force attack:** Opportunistic guessing attacks on authentication mechanisms based on authentication factors of the type knowledge, by guessing manually without the use of technical aids.

#### E.3.1.3 Authentication strength level normal

The authentication strength level normal shall protect against the following attack types:

**automated brute force attack:** Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical.

**presentation attack:** Presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using medium effort methods like e.g. photos, cut out masks, audio replays, video replays, AI generated voices.

**automated security token spoofing attack:** Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors sourced from other uses or self-created, without using any specific knowledge of the targeted authentication mechanisms.

**replay attack:** An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

**person in the middle attack:** An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

#### E.3.1.4 Authentication strength level enhanced

The authentication strength level enhanced shall protect against the following attack types:

**targeted presentation attack:** Presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using enhanced effort methods like e.g. (partial) silicone masks, layered prints.

**targeted brute force attack:** Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical aids, making use of target specific information.

**targeted security token spoofing attack:** Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors sourced from devices of the same type as the ICT or self-created, using specific knowledge of the targeted authentication mechanisms and the ICT.

**replay attack:** An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

**person in the middle attack:** An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

### E.3.1.5 Authentication strength level strong

The authentication strength level strong shall protect against the following attack types:

**elaborate presentation attack:** Presentation attacks on authentication mechanisms based on authentication factors of the type inheritance", using high effort methods like e.g. highly realistic silicone or latex masks, limb replicas, trained deepfakes.

**elaborate brute force attack:** Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical aids, making use of target specific information, and unrestricted duration.

**elaborate security token spoofing attack:** Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors created or sourced from devices of the same type as the ICT and modified, specifically for the targeted authentication mechanisms.

**replay attack:** An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

**person in the middle attack:** An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

## E.3.2 Assessment for authentication mechanism strength

### E.3.2.1 Assessment criteria regarding the protection against limited presentation attacks

#### Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a basic level of protection and use authentication factors of the type inheritance against limited presentation attacks.

#### Assessment preparation:

- the ICT shall be set up in default configuration;
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented.

#### Assessment activities:

- authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine enrolled biometric template identifier, if present, and authentication factors, not belonging to the person who set up the account, for at least five times or ten minutes at highest archivable query frequency;
- the outcome and used authentication factor of each attempt shall be recorded.

**Assignment of verdict:**

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- description of the performed test;
- all test records of the performed test.

### E.3.2.2 Assessment criteria regarding the protection against targeted presentation attacks

**Assessment objective:**

The assessment covers functional testing of authentication mechanisms that provide a enhanced level of protection and use authentication factors of the type inherence against targeted presentation attacks.

**Assessment preparation:**

- the ICT shall be set up in default configuration;
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- authentication factors shall be fabricated using common materials and tools as well as readily available source materials. The fabrication process shall not be longer than *one workday* per authentication factor.

**Assessment activities:**

- authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine enrolled biometric template identifier, if present, and at least two fabricated authentication factors tried at least five times with slightly different parameters each;
- the outcome and used authentication factor of each attempt shall be recorded.

**Assignment of verdict:**

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- description of the performed test;
- all test records of the performed test.

### E.3.2.3 Assessment criteria regarding the protection against elaborate presentation attacks

**Assessment objective:**

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type inherence against elaborate presentation attacks.

**Assessment preparation:**

- the ICT shall be set up in default configuration;

- 1615 • a genuine enrolled biometric template in the corresponding authentication mechanism with credential for  
1616 authentication shall be created;
- 1617 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1618 • authentication factors shall be fabricated using specialized materials and tools as well as cumbersome  
1619 extracted source materials. The duration of the fabrication process per authentication factor is not restricted.

1620 **Assessment activities:**

- 1621 • authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine  
1622 enrolled biometric template identifier, if present, and at least two fabricated authentication factors tried at least  
1623 five times with slightly different parameters each;
- 1624 • the outcome and used authentication factor of each attempt shall be recorded.

1625 **Assignment of verdict:**

1626 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

1627 The verdict FAIL shall be assigned otherwise.

1628 **Supporting Evidence:**

- 1629 • description of the performed test;
- 1630 • all test records of the performed test.

### 1631 E.3.2.4 Assessment criteria regarding the protection against limited brute 1632 force attacks

1633 **Assessment objective:**

1634 The assessment covers functional testing of authentication mechanisms that provide a basic level of protection and use  
1635 authentication factors of the type knowledge against limited brute force attacks.

1636 **Assessment preparation:**

- 1637 • the ICT shall be set up in default configuration;
- 1638 • at least one interface, where the authentication mechanism is reachable shall be documented.

1639 The security insurance time ( $T_{SI}$ ) for this assessment is 10 minutes (600 s).

1640 **Assessment activities:**

- 1641 • the minimal recommended complexity of passwords accepted by the mechanism ( $C_{PW,min}$ ) shall be  
1642 determined; e.g.  $C_{PW,min} = (10)^6$  for a 6-digit PIN or  $C_{PW,min} = \frac{9!}{(9-5)!}$  for a pattern of 5 nonrecurring nodes in  
1643 a field of 9 nodes;
- 1644 • the maximum sustained login attempt frequency ( $f_{LA,max}$ ) shall be determined; e.g.  $f_{LA,max} = \frac{5}{5 \cdot 3s + 3600s}$  for  
1645 3 seconds per login attempt + a one-hour waiting period after 5 failed login attempts;
- 1646 • the probability of guessing a completely random password of the minimal recommended complexity ( $p_{GRP}$ )  
1647 shall be calculated by  $p_{GRP} = T_{SI} \cdot f_{LA,max} / C_{PW,min}$ .

1648 The methods and outcome of each step shall be recorded.

1649 **Assignment of verdict:**

1650 The verdict PASS shall be assigned if the calculated probability  $p_{GRP}$  is less than  $10^{-2}$ .

1651 The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- the authentication mechanism and the interface via which it was accessed;
- all test records of the performed test.

### E.3.2.5 Assessment criteria regarding the protection against targeted brute force attacks

**Assessment objective:**

The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and use authentication factors of the type knowledge against targeted brute force attacks.

**Assessment preparation:**

- the ICT shall be set up in default configuration;
- at least one interface, where the authentication mechanism is reachable shall be documented.

The security insurance time ( $T_{SI}$ ) for this assessment one month ( $2,6 * 10^6 s$ ).

**Assessment activities:**

- the minimal recommended complexity of passwords accepted by the mechanism ( $C_{PW,min}$ ) shall be determined; e.g.  $C_{PW,min} = (26 * 2 + 10)^8$  for minimum 8 characters of upper-case or lower-case letters or numbers;
- the maximum sustained login attempt frequency ( $f_{LA,max}$ ) shall be determined; e.g.  $f_{LA,max} = (0,1s)^{-1}$  for 10 login attempt per second;
- the probability of guessing a completely random password of the minimal recommended complexity ( $p_{GRP}$ ) shall be calculated by  $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$ .

The methods and outcome of each step shall be recorded.

**Assignment of verdict:**

The verdict PASS shall be assigned if the calculated probability  $p_{GRP}$  is less than  $10^{-6}$ .

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- the authentication mechanism and the interface via which it was accessed;
- all test records of the performed test.

### E.3.2.6 Assessment criteria regarding the protection against automated brute force attacks

**Assessment objective:**

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type knowledge against targeted brute force attacks.

**Assessment preparation:**

- the ICT shall be set up in default configuration;
- at least one interface, where the authentication mechanism is reachable shall be documented.

The security insurance time ( $T_{SI}$ ) for this assessment is one day (86 400 s).

**Assessment activities:**

- the minimal recommended complexity of passwords accepted by the mechanism ( $C_{PW,min}$ ) shall be determined; e.g.  $C_{PW,min} = (26 * 2 + 10)^8$  for minimum 8 characters of upper-case case or lower-case letters or numbers;
- the maximum sustained login attempt frequency ( $f_{LA,max}$ ) shall be determined; e.g.  $f_{LA,max} = \frac{5}{5*3s+3600s}$  for 3 seconds per login attempt + a one-hour waiting period after 5 failed login attempts;
- the probability of guessing a completely random password of the minimal recommended complexity ( $p_{GRP}$ ) shall be calculated by  $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$ .

The methods and outcome of each step shall be recorded.

**Assignment of verdict:**

The verdict PASS shall be assigned if the calculated probability  $p_{GRP}$  is less than  $10^{-6}$ .

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- the authentication mechanism and the interface via which it was accessed;
- all test records of the performed test.

### E.3.2.7 Assessment criteria regarding the protection against presentation attacks

**Assessment objective:**

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type inherence against presentation attacks.

**Assessment preparation:**

- the ICT shall be set up in default configuration;
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- authentication factors shall be fabricated using readily available materials and tools as well as readily available source materials. The fabrication process shall not be longer than *twenty* minutes per authentication factor.

NOTE: Readily available source materials are e.g. fingerprints on everyday items or publicly available photos. Readily available materials and tools are of adhesive tape, printer paper, common printers.

**Assessment activities:**

- authentication at the created account shall be attempted using the correct account name, if present, and at least two fabricated authentication factors tried at least five times with slightly different parameters each;
- the outcome and used fabricated authentication factor of each attempt shall be recorded.

**Assignment of verdict:**

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- description of the performed test;

- all test records of the performed test.

### E.3.2.8 Assessment criteria regarding the protection against elaborate brute force attacks

#### Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type knowledge against targeted brute force attacks.

#### Assessment preparation:

- the ICT shall be set up in default configuration;
- at least one interface, where the authentication mechanism is reachable shall be documented.

The security insurance time ( $T_{SI}$ ) for this assessment is five years ( $1,6 * 10^8 s$ ).

#### Assessment activities:

- the minimal recommended complexity of passwords accepted by the mechanism ( $C_{PW,min}$ ) shall be determined; e.g.  $(26 * 2 + 10)^8$  for minimum 8 characters of upper-case case or lower-case letters or numbers;
- the maximum sustained login attempt frequency ( $f_{LA,max}$ ) shall be determined; e.g.  $(0,1s)^{-1}$  for 10 login attempt per second;
- the probability of guessing a completely random password of the minimal recommended complexity ( $p_{GRP}$ ) shall be calculated by  $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$ .

The methods and outcome of each step shall be recorded.

#### Assignment of verdict:

The verdict PASS shall be assigned if the calculated probability is less than  $10^{-6}$ .

The verdict FAIL shall be assigned otherwise.

#### Supporting Evidence:

- the authentication mechanism and the interface via which it was accessed;
- all test records of the performed test.

### E.3.2.9 Assessment criteria regarding the protection against automated security token spoofing attacks

#### Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type possession against automated security token spoofing attacks.

#### Assessment preparation:

- the ICT shall be set up in default configuration;
- an account in the corresponding authentication mechanism with a security token for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- security tokens, that match specifications of the interfaces, via which the authentication mechanism is reachable, shall be prepared or created without using any specific knowledge of the authentication mechanism.

1763 **Assessment activities:**

- 1764 • authentication at the created account shall be attempted using the correct account name, if present, and the  
1765 prepared or created security tokens;
- 1766 • the outcome and used authentication factor of each attempt shall be recorded.

1767 **Assignment of verdict:**

1768 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used  
1769 authentication factor exactly matches the configured one.

1770 The verdict FAIL shall be assigned otherwise.

1771 **Supporting Evidence:**

- 1772 • description of the performed test;
- 1773 • all test records of the performed test.

1774 **E.3.2.10 Assessment criteria regarding the protection against targeted**  
1775 **security token spoofing attacks**

1776 **Assessment objective:**

1777 The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and  
1778 use authentication factors of the type possession against targeted security token spoofing attacks.

1779 **Assessment preparation:**

- 1780 • the ICT shall be set up in default configuration;
- 1781 • an account in the corresponding authentication mechanism with a security token for authentication shall be  
1782 created;
- 1783 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1784 • security tokens, shall be prepared or created, which match the specifications of the authentication mechanism.

1785 **Assessment activities:**

- 1786 • authentication at the created account shall be attempted using the correct account name, if present, and the  
1787 prepared or created security tokens;
- 1788 • the outcome and used authentication factor of each attempt shall be recorded.

1789 **Assignment of verdict:**

1790 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used  
1791 authentication factor exactly matches the configured one.

1792 The verdict FAIL shall be assigned otherwise.

1793 **Supporting Evidence:**

- 1794 • description of the performed test;
- 1795 • all test records of the performed test.



### E.3.2.11 Assessment criteria regarding the protection against elaborate security token spoofing attacks

#### Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type possession against elaborate security token spoofing attacks.

#### Assessment preparation:

- the ICT shall be set up in default configuration;
- an account in the corresponding authentication mechanism with a security token for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- security tokens, shall be prepared or created, which match the specifications of the authentication mechanism and use information extracted from the original security token.

#### Assessment activities:

- authentication at the created account shall be attempted using the correct account name, if present, and the prepared or created security tokens;
- the outcome and used authentication factor of each attempt shall be recorded.

#### Assignment of verdict:

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used authentication factor exactly matches the configured one.

The verdict FAIL shall be assigned otherwise.

#### Supporting Evidence:

- description of the performed test;
- all test records of the performed test.

### E.3.2.12 Assessment criteria regarding the protection against replay attacks

#### Assessment objective:

The assessment covers functional testing of authentication mechanisms that use authentication factors of the type knowledge or possession (e.g. a session token) against replay attacks.

#### Assessment preparation:

- the ICT shall be set up in default configuration;
- the authentication mechanism shall be active;
- a communication partner with active authentication mechanisms shall be set up for the ICT;
- a capture and replay tool between ICT and its communication partner shall be set up;
- at least one interface, where the authentication mechanism is reachable shall be documented.

#### Assessment activities:

- Initiate a connection between the ICT and its communication partner.
- Use a capture tool to record the transmitted message or transaction data.

1832       •     Replay (retransmit) the captured message to the product using a suitable tool in place to mimic the original  
1833               communication partner.

1834       •     Record if the product accepts the retransmitted data.

1835     **Assignment of verdict:**

1836     The verdict PASS shall be assigned if it is not possible to impersonate as the communication partner.

1837     The verdict FAIL shall be assigned otherwise.

1838     **Supporting Evidence:**

1839       •     description of the performed test;

1840       •     all test records of the performed test.

1841     **E.3.2.13 Assessment criteria regarding the protection against PitM attacks**

1842     **Assessment objective:**

1843     The assessment covers functional testing of authentication mechanisms that use authentication factors of the type  
1844     knowledge or possession (e.g. a session token) against PitM attacks.

1845     **Assessment preparation:**

1846       •     the ICT shall be set up in default configuration;

1847       •     the authentication mechanism shall be active;

1848       •     a communication partner with active authentication mechanisms shall be set up for the ICT;

1849       •     a capture and PitM tool between ICT and its communication partner shall be set up;

1850       •     at least one interface, where the authentication mechanism is reachable shall be documented.

1851     **Assessment activities:**

1852       •     Initiate a connection between the ICT and its communication partner.

1853       •     Attempt to capture data (consumer credentials, tokens, etc.) with the tool in place and actively intercept  
1854               communication to impersonate the communication partner during:

1855           -     generation and communication of authentication factors for the communication partner (if not  
1856               pre-configured); and

1857           -     authentication of the communication partner.

1858       •     Record if the impersonation as communication partner is successful.

1859     **Assignment of verdict:**

1860     The verdict PASS shall be assigned if it is not possible to impersonate as the communication partner.

1861     The verdict FAIL shall be assigned otherwise.

1862     **Supporting Evidence:**

1863       •     description of the performed test;

1864       •     all test records of the performed test.

---

## E.4 confidentiality protection strength

### E.4.1 CONF-SSM Confidentiality protecting persistent storage for confidential data

#### E.4.1.1 General

The present document specifies confidentiality protecting secure storage mechanisms' strength, by certain security properties. Those properties are constructed such that mechanisms of higher strength have the properties of lower strength mechanisms.

#### E.4.1.2 confidential persistent storage strength level basic

Mechanisms for the confidential persistent storage strength level basic shall encrypt such that decryption is only possible for the ICT.

#### E.4.1.3 confidential persistent storage strength level normal

Mechanisms for the confidential persistent storage strength level normal shall encrypt such that decryption is:

- only possible for the ICT; and
- only performed after a successful authentication.

#### E.4.1.4 confidential persistent storage strength level enhanced

Mechanisms for the confidential persistent storage strength level enhanced shall encrypt supported by hardware, such that:

- decryption is only possible for the ICT after a successful authentication; and
- the extraction of the encryption key is prevented by hardware.

#### E.4.1.5 confidential persistent storage strength level strong

Mechanisms for the confidential persistent storage strength level strong shall prevent the extraction of data by hardware.

---

## E.5 confidentiality protection strength

### E.5.1 CONF-COM Communication of confidential data

#### E.5.1.1 General

The present document specifies the strength of mechanisms to protect the confidentiality of communicated confidential data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

#### E.5.1.2 Communication of confidential data protection strength level basic

The communication of confidential data protection strength level basic shall protect against the following attack types:

- **eavesdropping:** An attacker secretly intercepts the communication between the ICT and another entity or another part of the ICT.

### E.5.1.3 Communication of confidential data protection strength level normal

The communication of confidential data protection strength level normal shall protect against the following attack types:

- **eavesdropping:** An attacker secretly intercepts the communication between the ICT and another entity or another part of the ICT.
- **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the ICT.
- **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

### E.5.1.4 Communication of confidential data protection strength level enhanced

The communication of confidential data protection strength level enhanced shall protect against the following attack types:

- **eavesdropping:** An attacker secretly intercepts the communication between the ICT and another entity or another part of the ICT.
- **person in the middle attack:** An attacker secretly alters the communication between the ICT and another entity or another part of the ICT to gain a trusted relationship with the involved communication partners without their knowledge.
- **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the ICT.
- **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

### E.5.1.5 Communication of confidential data protection strength level strong

The communication of confidential data protection strength level strong shall protect against the following attack types:

- **eavesdropping:** An attacker secretly intercepts the communication between the ICT and another entity or another part of the ICT.
- **person in the middle attack:** An attacker secretly alters the communication between the ICT and another entity or another part of the ICT to gain a trusted relationship with the involved communication partners without their knowledge.
- **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the ICT.
- **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

---

## E.6 Integrity protection strength

### E.6.1 INT-SWPCK Software package verification

#### E.6.1.1 General

The present document specifies software package verification mechanisms' strength, by certain protection measures. Those measures are constructed such that measures of higher strength typically have less attack vectors than lower strength measures.

### E.6.1.2 Software package integrity verification strength level basic

Mechanisms for the software package integrity verification strength level basic shall:

- explicitly obtain the confirmation of an authorized entity that the integrity and authenticity of a software package has been verified by the entity, where the software package's source is determined by the entity; or
- explicitly obtain the confirmation of an authorized entity that the authenticity of a software package has been verified by the entity and use a hash or checksum provided by the entity for the software package to verify its integrity, where the software package's source is determined by the entity.

### E.6.1.3 Software package integrity verification strength level normal

Mechanisms for the software package integrity verification strength level normal shall ensure that a software package has been obtained from a trusted source over a secure communication channel that meets INT.COM.Enhanced.

### E.6.1.4 Software package integrity verification strength level enhanced

Mechanisms for the software package integrity verification strength level enhanced shall verify the authenticity and integrity of a software package using cryptographic digital signature verification.

## E.6.2 INT-COM Communication of integrity relevant data

### E.6.2.1 General

The present document specifies the strength of mechanisms to protect the integrity of communicated integrity relevant data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

### E.6.2.2 Communication of integrity relevant data protection strength level basic

The communication of integrity relevant data protection strength level basic shall protect against the following attack types:

- **accidental bit flip:** Accidental change of data by natural causes.

### E.6.2.3 Communication of integrity relevant data protection strength level normal

The communication of integrity relevant data protection strength level normal shall protect against the following attack types:

- **replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same interface to deceive it into performing unauthorized actions.
- **accidental bit flip:** Accidental change of data by natural causes.
- **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the ICT.
- **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

#### E.6.2.4 Communication of integrity relevant data protection strength level enhanced

The communication of integrity relevant data protection strength level enhanced shall protect against the following attack types:

- **replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same interface to deceive it into performing unauthorized actions.
- **person in the middle attack:** An attacker secretly alters the communication between the ICT and another entity or another part of the ICT to gain a trusted relationship with the involved communication partners without their knowledge.
- **accidental bit flip:** Accidental change of data by natural causes.
- **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the ICT.
- **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

#### E.6.2.5 Communication of integrity relevant data protection strength level strong

The communication of integrity relevant data protection strength level strong shall protect against the following attack types:

- **replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same interface to deceive it into performing unauthorized actions.
- **person in the middle attack:** An attacker secretly alters the communication between the ICT and another entity or another part of the ICT to gain a trusted relationship with the involved communication partners without their knowledge.
- **accidental bit flip:** Accidental change of data by natural causes.
- **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the ICT.
- **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

## Annex F (informative): Relationship between the present document and the covered/not covered cybersecurity risks

This informative annex is intended to provide the relevant information on the covered/not covered cybersecurity risks and still under discussion.

The information provided in the column "Risk coverage" is based on a preliminary analysis which is planned to be expanded in the future and still under discussion.

Table F.1 shows the threat scenarios considered, the mitigation measures related to them in this document with associated attack surface parameters, and the risk coverage.

**Table F.1: Covered threats and remaining risks acceptance**

| No. | Threat Actor   | Threat action | Asset                               | Threat details                         |                         | Requirement(s) for mitigation                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Relevant attack surface parameter | Risk coverage |
|-----|----------------|---------------|-------------------------------------|----------------------------------------|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|---------------|
| [1] | A threat actor | (mis)uses     | a function whose use can cause harm | on the ICT                             |                         | <b>Prevention:</b><br>[ACM-FH] <a href="#">5.1.3.1</a><br>[AUM-FH] <a href="#">5.1.3.3</a><br>[AUTHZ-LP] <a href="#">5.1.3.4</a><br>[AUTHZ-R] <a href="#">5.1.3.5</a><br>[AUTHZ-PC] <a href="#">5.1.3.6</a><br>[AVAI-TIME-IMP-AMP] <a href="#">5.1.7.8</a><br>[LAS-PHY-INF] <a href="#">5.1.9.3</a><br>[LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[PARCONT] <a href="#">5.1.3.2</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a><br>[SDC-PARCONT] <a href="#">5.1.2.5</a><br><b>Information:</b><br>[LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[LOG-TIME] <a href="#">5.1.10.4</a><br>[LOG-TIME-HIGH] <a href="#">5.1.10.5</a><br>[LOG-STORAGE] <a href="#">5.1.10.6</a><br>[LOG-BACKUP] <a href="#">5.1.10.7</a><br>[USERNOT-NOSECFUC] <a href="#">5.1.12.1</a><br><b>Restoration:</b><br>[SDC-FRM] <a href="#">5.1.2.4</a> | COM, IF and POE                   | C             |
| [2] |                | tampers       | integrity relevant data             | permanently stored on the ICT          |                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |                                   | N             |
| [3] |                |               |                                     | volatile stored on the ICT             |                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |                                   | N             |
| [4] |                |               |                                     | communicated from or to the MP or RDPS |                         | <b>Prevention:</b><br>[INT-COM] <a href="#">5.1.4.2</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | COM, IF and POE                   | C             |
| [5] |                | discloses     | confidential data                   | on the ICT                             | unnecessarily processed | <b>Prevention:</b><br>[DMIN-DJST] <a href="#">5.1.6.1</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |                                   | C             |
| [6] |                |               |                                     | permanently stored on the ICT          | during storage          | <b>Prevention:</b><br>[CONF-SSM] <a href="#">5.1.5.1</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | POE                               | C             |

| No.  | Threat Actor | Threat action               | Asset                       | Threat details                         |                                                          | Requirement(s) for mitigation                                                                                                                                                                                                                                 | Relevant attack surface parameter | Risk coverage |
|------|--------------|-----------------------------|-----------------------------|----------------------------------------|----------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|---------------|
| [7]  |              |                             |                             |                                        | after deletion                                           |                                                                                                                                                                                                                                                               |                                   | N             |
| [8]  |              |                             |                             | volatile stored on the ICT             | during usage                                             |                                                                                                                                                                                                                                                               |                                   | N             |
| [9]  |              |                             |                             |                                        | after usage                                              |                                                                                                                                                                                                                                                               |                                   | N             |
| [10] |              |                             |                             | communicated from or to the MP or RDPS |                                                          | <b>Prevention:</b><br>[CONF-COM] <a href="#">5.1.5.2</a>                                                                                                                                                                                                      | COM, IF and POE                   | C             |
| [11] |              | tamperers                   | loss sensitive data         | permanently stored on the ICT          | during storage                                           |                                                                                                                                                                                                                                                               |                                   | N             |
| [12] |              |                             | integrity relevant function | on the ICT                             |                                                          | <b>Prevention:</b><br>[INT-SWPCK] <a href="#">5.1.4.1</a><br>[LAS-SBOOT] <a href="#">5.1.9.6</a>                                                                                                                                                              |                                   | N             |
| [13] |              | impacts the availability of | time sensitive function     |                                        | by interruption caused by a software update installation | <b>Prevention:</b><br>[AVAI-SUM-SCHEDULE] <a href="#">5.1.7.10</a>                                                                                                                                                                                            |                                   | C             |
| [14] |              |                             |                             |                                        | by interruption of power supply                          | <b>Information:</b><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br><b>Restoration:</b><br>[AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a>                                                                    |                                   | C             |
| [15] |              |                             |                             |                                        | by interruption of network connection                    | <b>Prevention:</b><br>[AVAI-TIME-NETW] <a href="#">5.1.7.2</a><br><b>Information:</b><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br><b>Restoration:</b><br>[AVAI-TIME-RECO-NETW] <a href="#">5.1.7.3</a> |                                   | C             |
| [16] |              |                             |                             |                                        | due to overloading of a resource or connection           | <b>Prevention:</b><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a><br>[AVAI-TIME-DOS-RATE] <a href="#">5.1.7.9</a><br><b>Information:</b><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a>                     | IF                                | C             |



| No.  | Threat Actor | Threat action                                             | Asset                         | Threat details |  | Requirement(s) for mitigation                                                                                                                                                                                                                                                                                                                                                                                                                                 | Relevant attack surface parameter | Risk coverage |
|------|--------------|-----------------------------------------------------------|-------------------------------|----------------|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|---------------|
| [17] |              | exploits an implementation on vulnerability to compromise | a product cybersecurity asset |                |  | <b>Prevention:</b><br>[LAS-INVAL] <a href="#">5.1.9.1</a><br>[LAS-INSAN] <a href="#">5.1.9.2</a><br>[NKEV-MKAV] <a href="#">5.1.1.1</a><br><b>Information:</b><br>[NKEV-SUM-NOTIF] <a href="#">5.1.1.5</a><br>[SDC-SUM-NOTIF] <a href="#">5.1.2.3</a><br><b>Restoration:</b><br>[NKEV-SUM-SUPPORT] <a href="#">5.1.1.2</a><br>[NKEV-SUM-PROVIDE] <a href="#">5.1.1.3</a><br>[NKEV-SUM-AUTO] <a href="#">5.1.1.4</a><br>[SDC-SUM-AUTO] <a href="#">5.1.2.2</a> |                                   | C             |

2002

2003

2004

- The columns *Threat Actor*, *Threat Action*, *Asset*, and *Threat Details* describe the threat scenario under consideration.

2005

2006

- The column *Requirement(s) for mitigation* refers to the mitigations of the risks that arise from the threat scenario.

2007

2008

- The *Relevant attack surface parameter* column describes which of the attack surface parameters make a difference in mitigation.

2009

2010

- The *Risk coverage* column describes whether the risk associated with the threat scenario has been reduced to an acceptable residual risk (C) or not (N).

2011

---

2012 Annex G (informative):  
2013 Relationship between the present document and ETSI EN  
2014 303 645/ ETSI TS 103 701

2015 This informative annex is intended to provide a mapping between the present document and the content of ETSI  
2016 TC CYBER's existing work on CIoT devices (ETSI EN 303 645/ ETSI TS 103 701).

2017

2018

---

## History

| Version | Date          | Status                                                                                                                |
|---------|---------------|-----------------------------------------------------------------------------------------------------------------------|
| V0.2.3  | February 2026 | Clean-up done by <i><a href="#">editHelp!</a></i><br>E-mail: <a href="mailto:edithelp@etsi.org">edithelp@etsi.org</a> |
|         |               |                                                                                                                       |
|         |               |                                                                                                                       |
|         |               |                                                                                                                       |
|         |               |                                                                                                                       |

2019